



Continuous Security with DevSecOps

How Platform Engineering Transforms Modern Application Security

Romano Roth | 19.02.2025 | Zürich

My passion is helping companies bringing people, processes and technology together so that they can deliver continuously value to their customers



Romano Roth

Chief of DevOps & Partner

✉ romano.roth@zuehlke.com

🏠 <https://www.romanoroth.com/>

🐦 [@RomanoRoth](https://twitter.com/RomanoRoth)

in [Romanoroth](https://www.linkedin.com/company/romanoroth)

📺 [RomanoRoth](https://www.youtube.com/channel/UCRomanoRoth)

🌀 [DevOps Meetup Zürich](https://www.meetup.com/DevOps-Meetup-Zurich)

🧠 [DevOpsDays Zürich](https://www.meetup.com/DevOpsDays-Zurich)

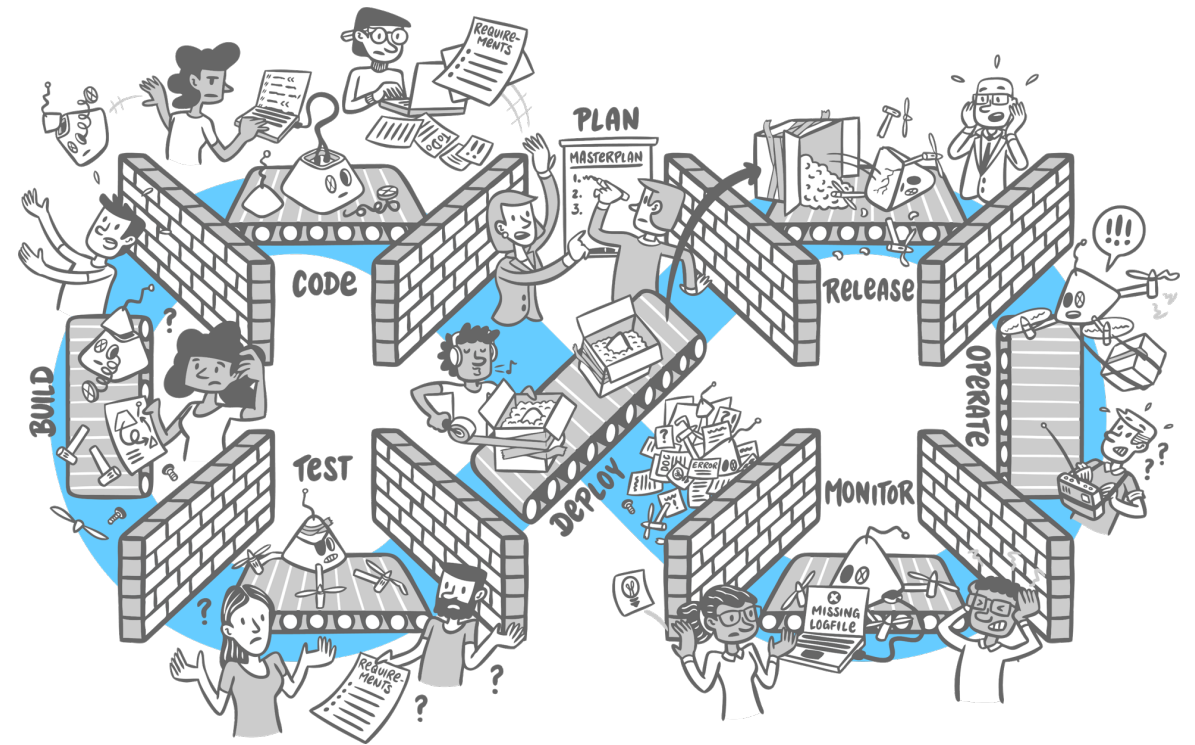
HSLU [CAS Digital Transformation](https://www.hslu.ch/de/cas/digital-transformation)

HSLU [CAS Enterprise Architecture](https://www.hslu.ch/de/cas/enterprise-architecture)

HSLU [CAS DevOps Leadership and Agile Methods](https://www.hslu.ch/de/cas/devops-leadership-and-agile-methods)

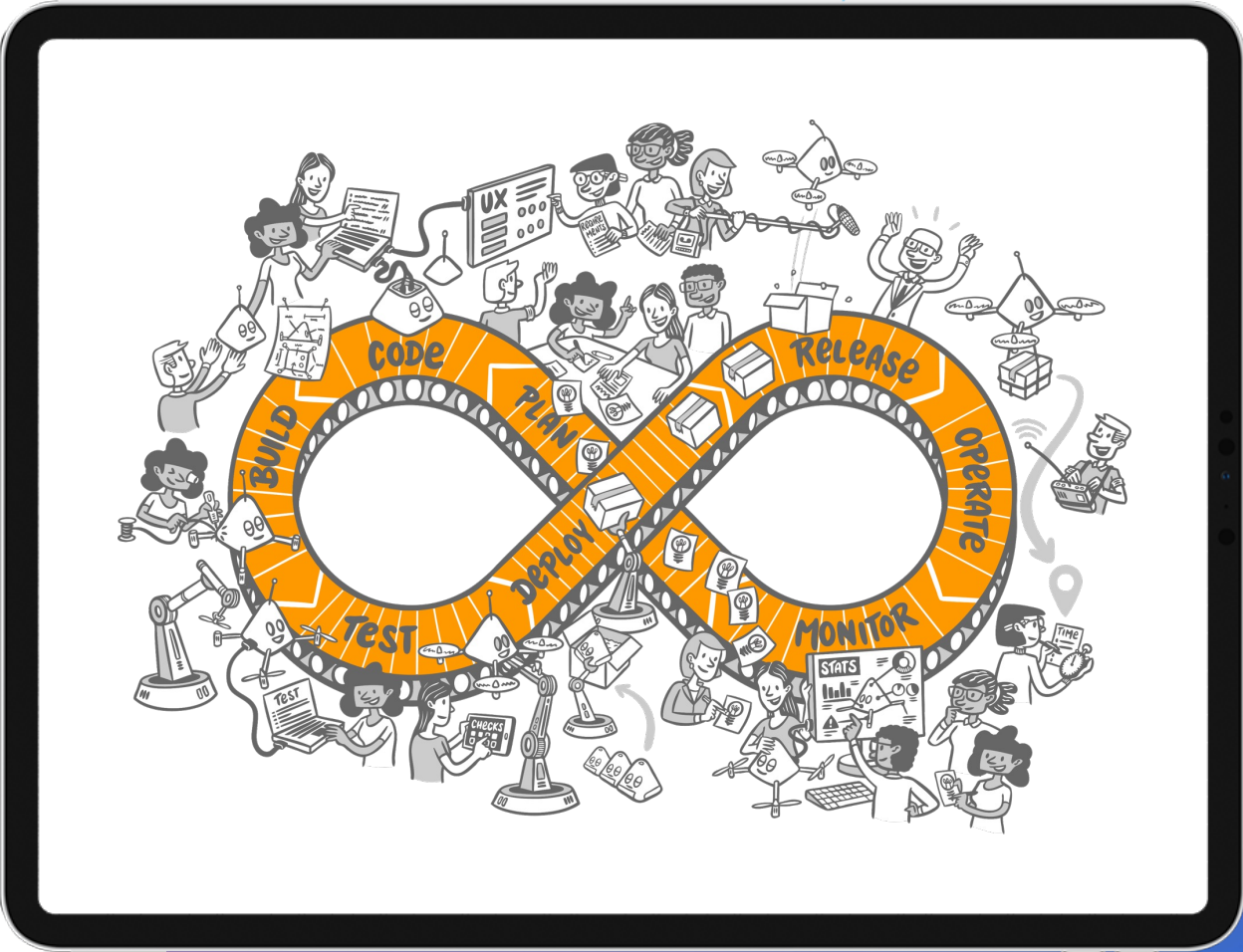
Today's challenges

- Silo Organization
- Legacy system, technology
- Inflexible and slow processes
- No alignment
- Security and quality is an aftermath
- Cultural resistance
- Regulatory and Compliance



DevSecOps is here to help

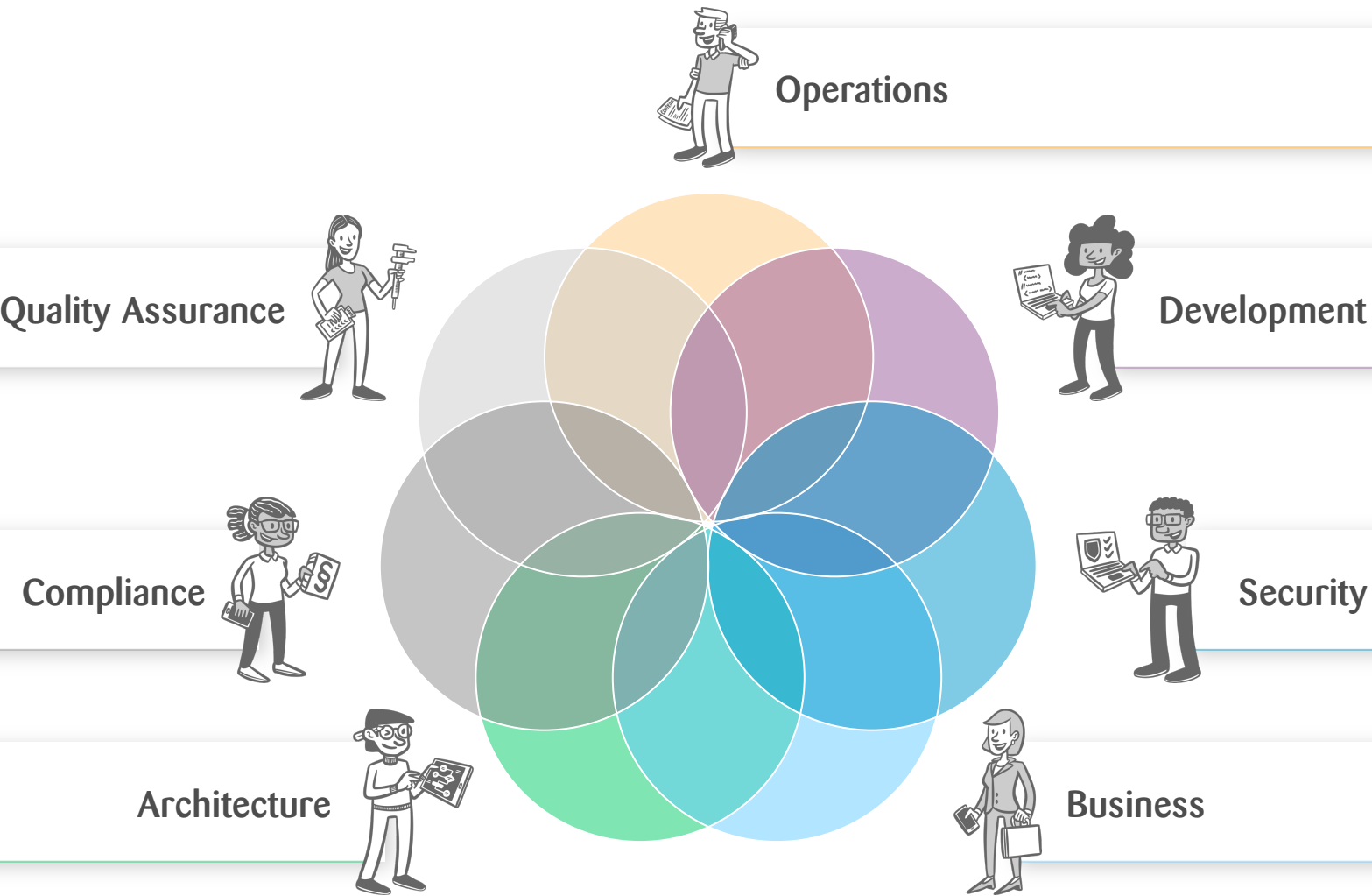
Continuously deliver



DevSecOps is a **mindset**, a **culture**, and a set of technical **practices**. It provides communication, integration, automation, and close cooperation among all the people needed to plan, develop, test, deploy, release, and maintain a product.

Who is DevSecOps

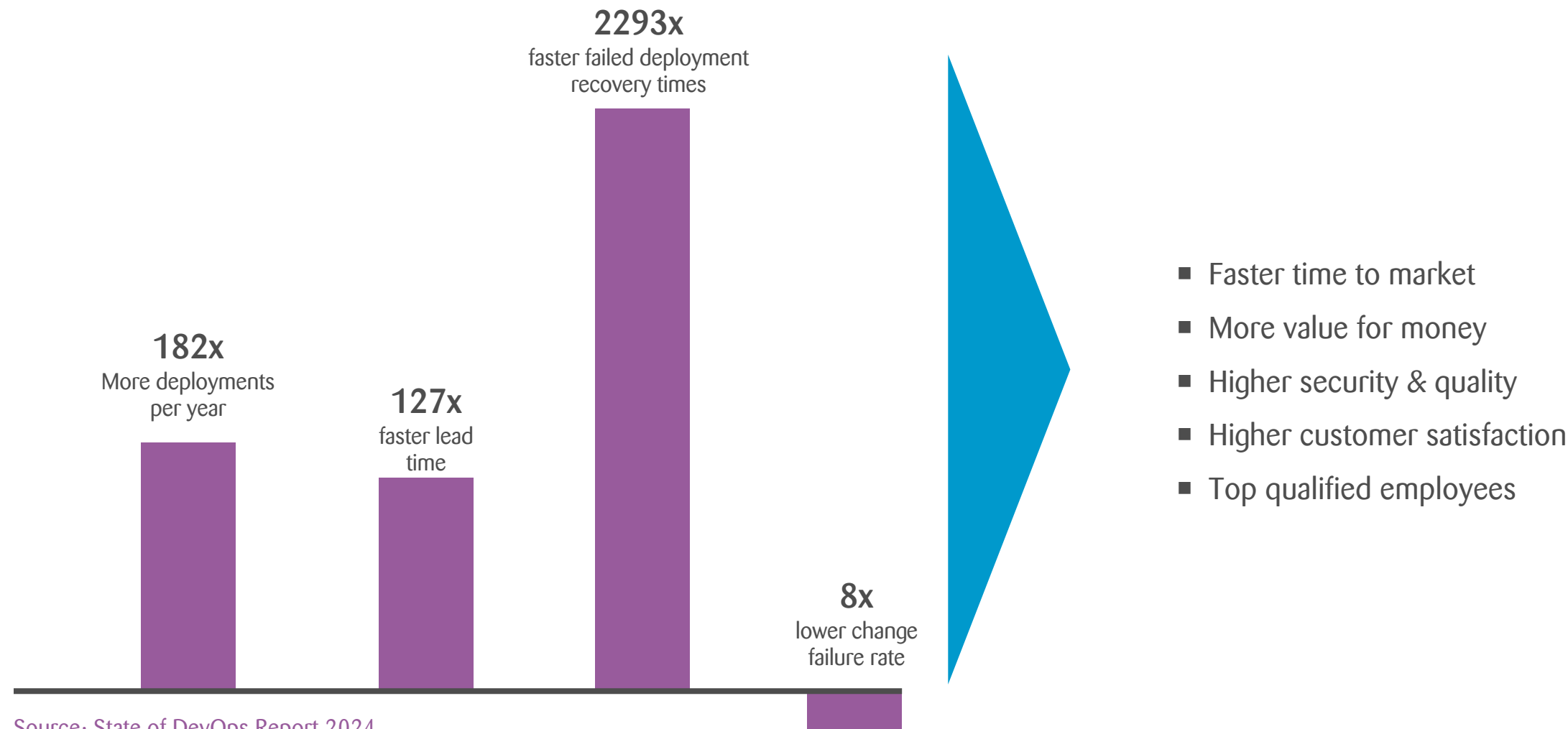
Everyone contributing to the value stream



**DevSecOps:
Bringing People, Process
and Technology together to
continuously deliver value!**

The benefits of the DevSecOps

Comparing highest to lowest performers



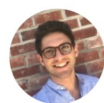
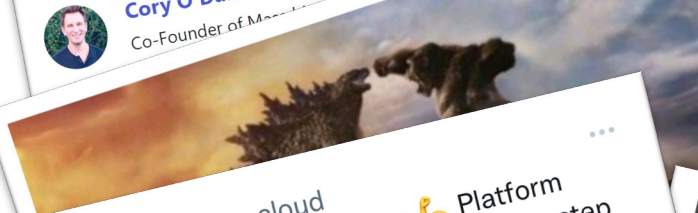
All good, but...

DevOps is Bullshit

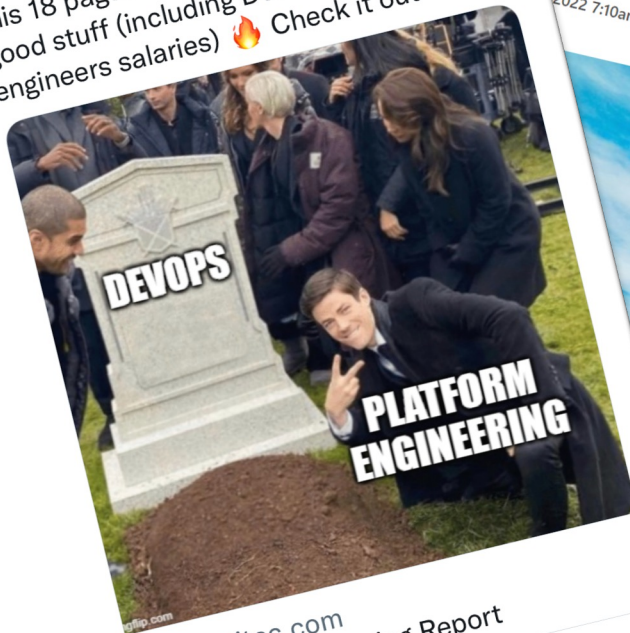
October 19, 2022 · 12 min read



Cory O'Daniel
Co-Founder of M...



Luca @luca_cloud
Like DevOps, just better 💪 Platform Engineering is the next evolutionary step in cloud native 📌 I spoke to 500+ dev teams and summarized my learnings in this 18 pages report, packed with all the good stuff (including DevOps vs Platform engineers salaries) 🔥 Check it out



humanitec.com
Platform Engineering Report



669



Sid Palas
@sidpalas

DevOps is dead 🧟, long live Platform Engineering!
Developers don't like dealing with infra
Companies need control of their infra as they grow
Engineering (and Internal Developer
enable these two facts to coexist. Here's

DevOps Is Dead. Embrace Platform Engineering

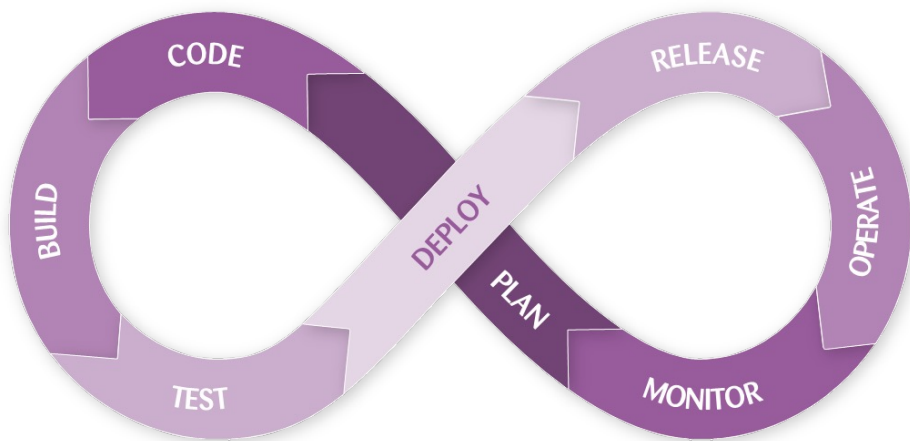
Forms provide golden paths, with recommended tools and best security practices
n, reducing cognitive load while preserving developer freedom.



What are the challenges with DevSecOps?

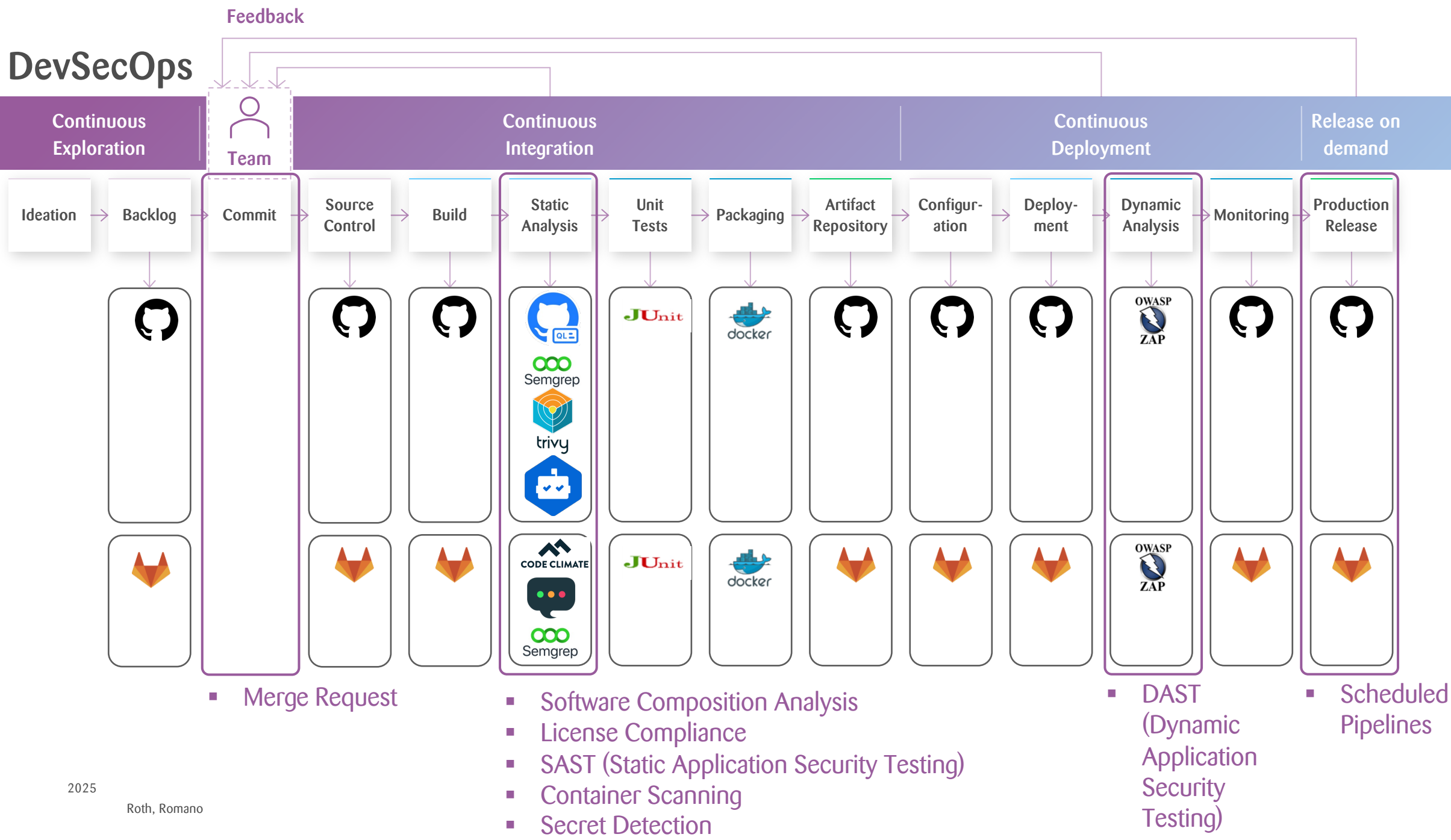
Modern Software Development is a continuous process across the value stream

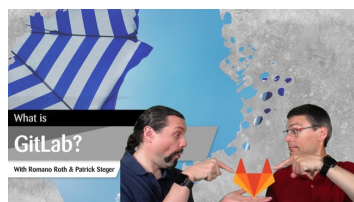
DevSecOps is a mindset, a culture, and a set of **technical practices**.



Plan	Code	Build	Test	Deploy	Operate	Release	Monitor
▪ Backlog management ▪ Value Stream Management ▪ UX ▪ Lean Portfolio Management ▪ BDD ▪ Architecture ▪ Quality Management ▪ Agile SW Architecture ▪ DoR	▪ Git ▪ IDE ▪ IaC ▪ Code Review (PR) ▪ Documentation ▪ Secret Mgmt. ▪ Agile SWE ▪ TDD ▪ Remote Development ▪ Emergent SW Architecture	▪ Continuous Integration ▪ Software Composition Analysis ▪ License Compliance ▪ SAST ▪ Container Scanning ▪ Secret Detection ▪ Container Registry	▪ Test Automation ▪ Test Data Management ▪ Vulnerability Management ▪ Compliance Management ▪ Audit Security Policy Management ▪ DoD	▪ DAST ▪ API Security ▪ Scheduled Pipelines ▪ Environment Management ▪ Deployment automation ▪ Staging environment ▪ Continuous Delivery / Deployment ▪ Production Testing	▪ Cross-team collaboration ▪ Proactive detection ▪ Logging ▪ Tracing	▪ Release Orchestration ▪ Feature flags ▪ Canary releases ▪ Dark launches	▪ Continuous Monitoring ▪ Full-stack telemetry ▪ Visual displays ▪ Federated monitoring ▪ Observability ▪ Metrics (DORA) ▪ On-Call Schedule Mgmt. ▪ Incident Mgmt. ▪ Service desk ▪ Software Bill of Material

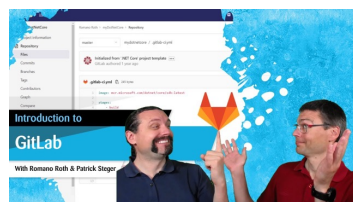
DevSecOps





What is GitLab?

<https://youtu.be/sHK8uN5fBhs>



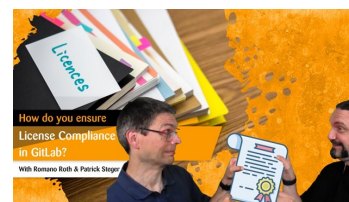
Introduction to GitLab

<https://youtu.be/GQ3x9bkCK90>



SCA

https://youtu.be/l69W5Ym_M5o



License Compliance

https://youtu.be/Kmbj_PCiHyk



SAST

<https://youtu.be/owwIMUamdDc>



Container Scanning

<https://youtu.be/1AUKQ32K6D4>



Secret Detection

<https://youtu.be/Qs28ONnj00s>



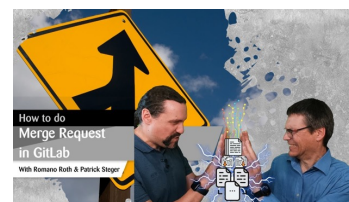
DAST

<https://youtu.be/ly1OiuPZrKs>



Vulnerability Management

<https://youtu.be/XSrlVvv0H1c>



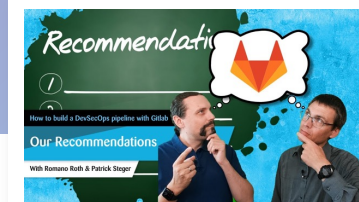
Merge Request

<https://youtu.be/h4AN7S2qwuq>



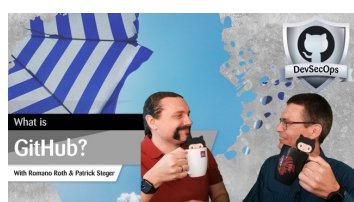
Schedule Pipeline

<https://youtu.be/PqPW3zQeP94>



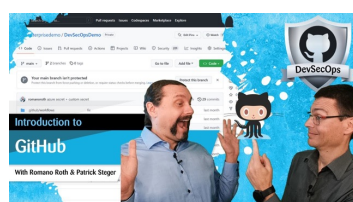
Recommendations

<https://youtu.be/dphgw9xxjuw>



What is GitHub?

https://youtu.be/_m5KYEi1ThA



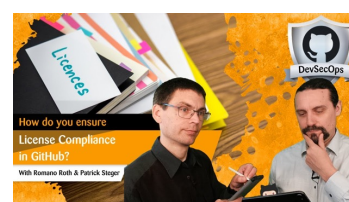
Introduction to GitHub

<https://youtu.be/6ZdxXDu8ZDA>



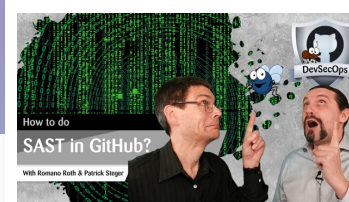
SCA

<https://youtu.be/xM3elerxjYo>



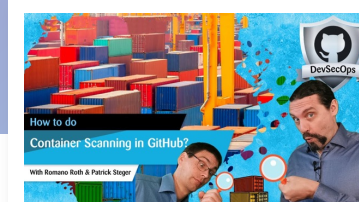
License Compliance

<https://youtu.be/l7lBh2xkDcQ>



SAST

<https://youtu.be/p4xS2X5KsNk>



Container Scanning

https://youtu.be/_ZeKh3GcbqU



Secret Detection

<https://youtu.be/k-uuPTLNxGM>



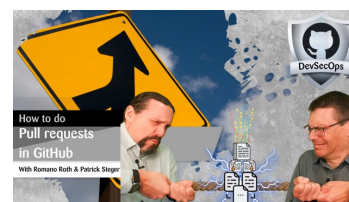
DAST

https://youtu.be/_v_xo1kqNYsE



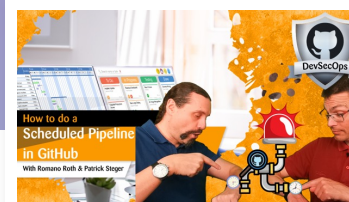
Vulnerability Management

<https://youtu.be/XSrlVvv0tbd>



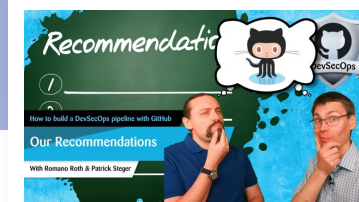
Pull Requests

<https://youtu.be/h4AN7S2qtbd>



Schedule Pipeline

<https://youtu.be/PqPW3zQetbd>



Recommendations

<https://youtu.be/dphgw9xtbdt>

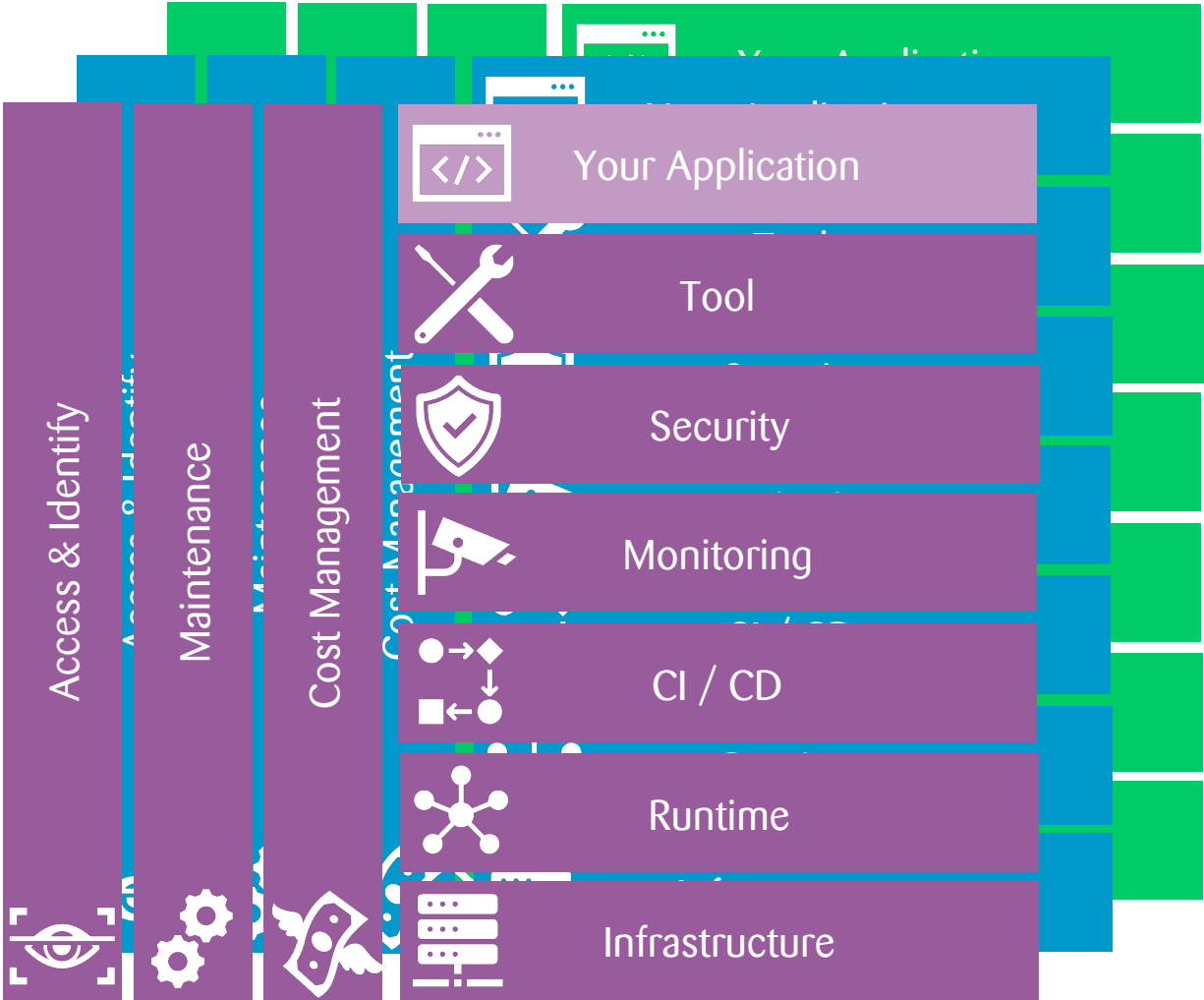
You need to take care about the full stack

You Build it you Run it!



Think about that on scale...

The cognitive load is too high!



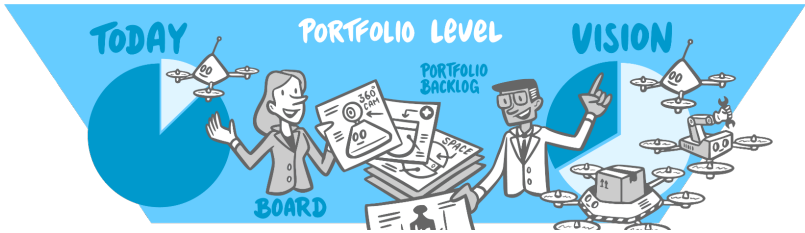
- Inconsistent and redundant platforms
 - Lack of operations experience in development
 - Complexity in tools
- 👉 The cognitive load is too high

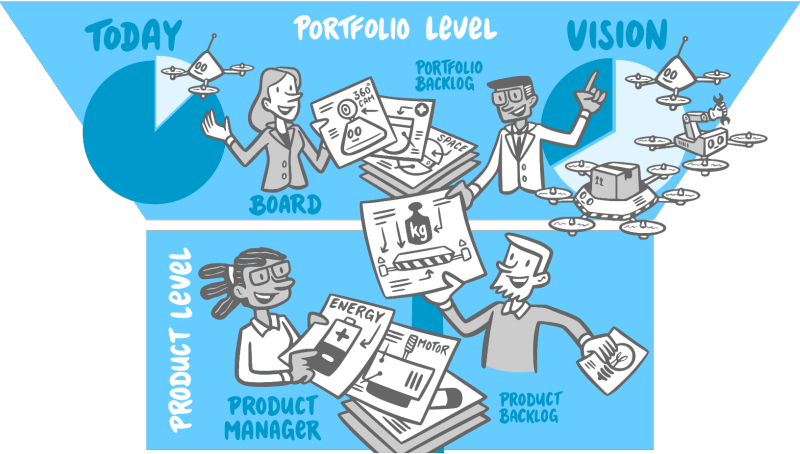


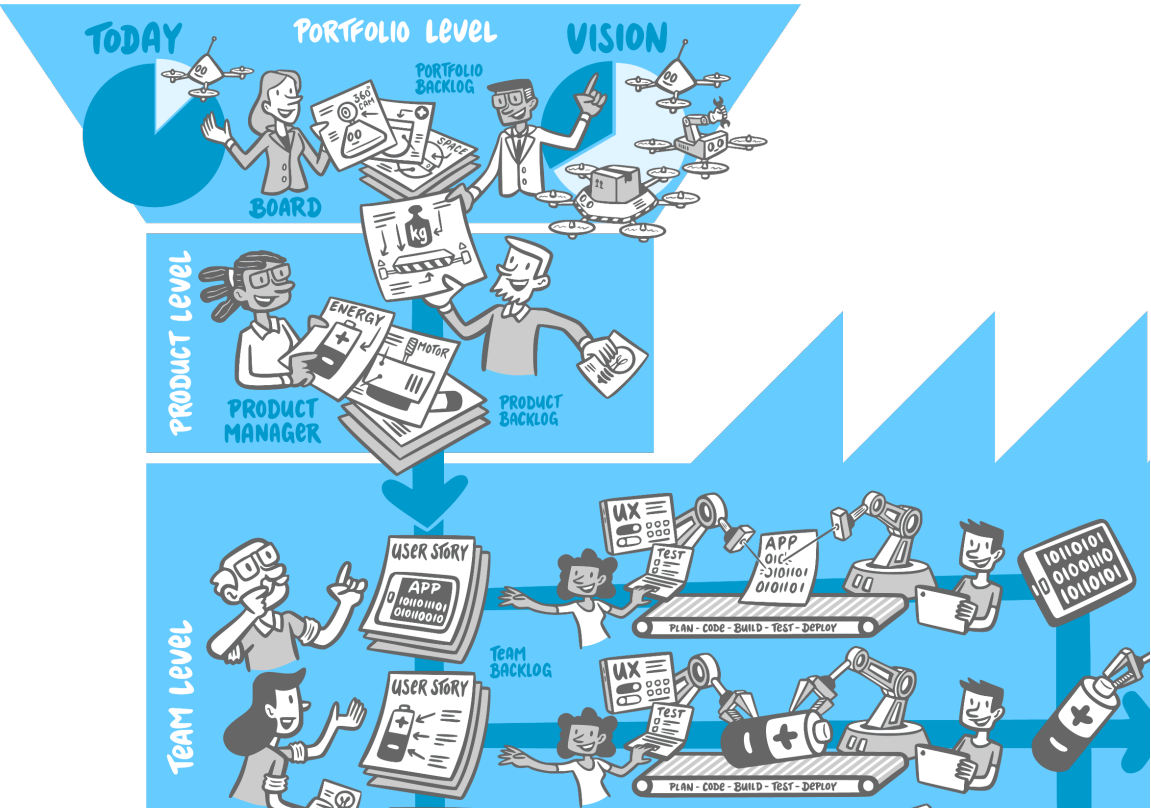
Can you scale DevSecOps?

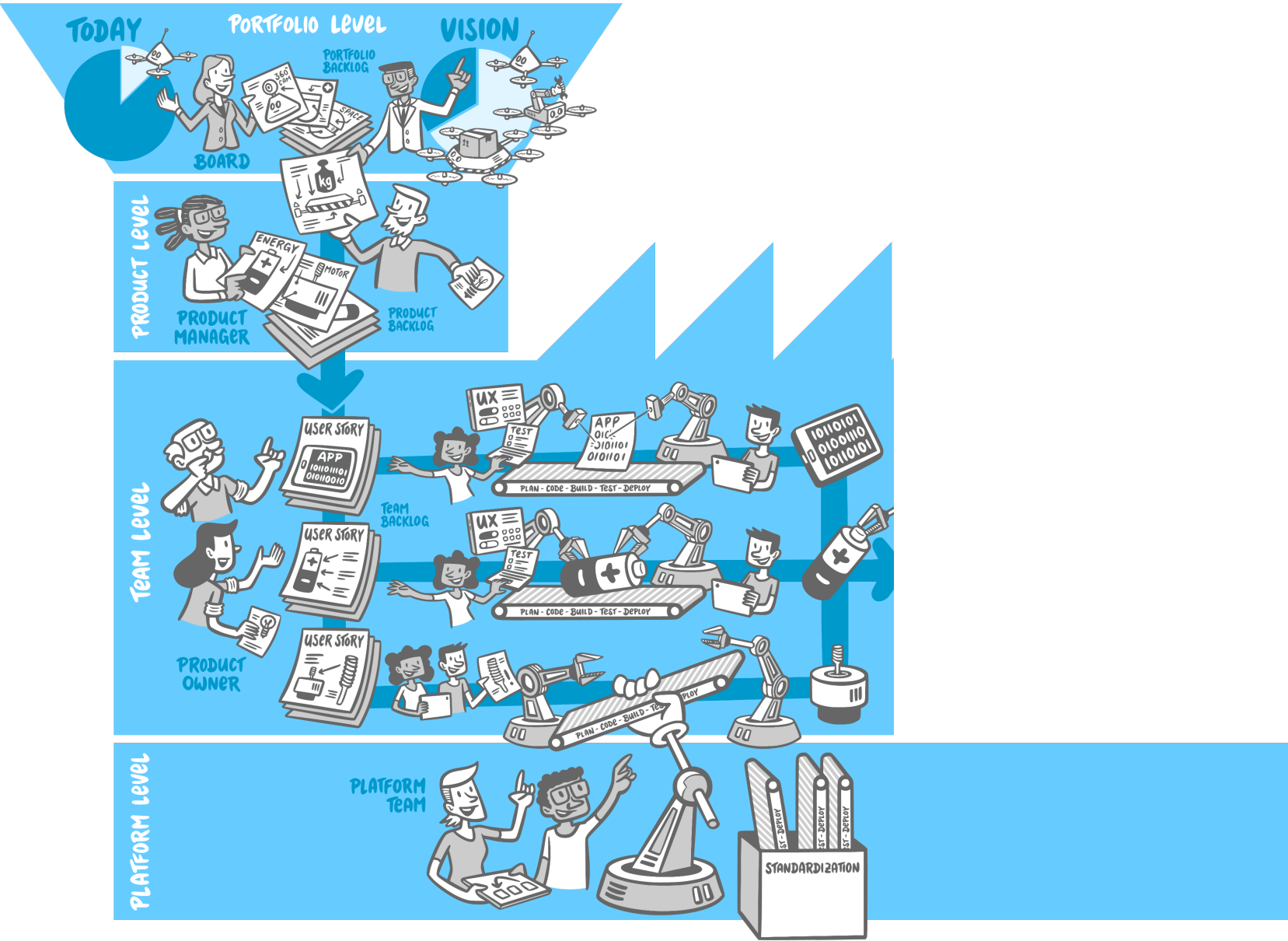
Let's take a step back!

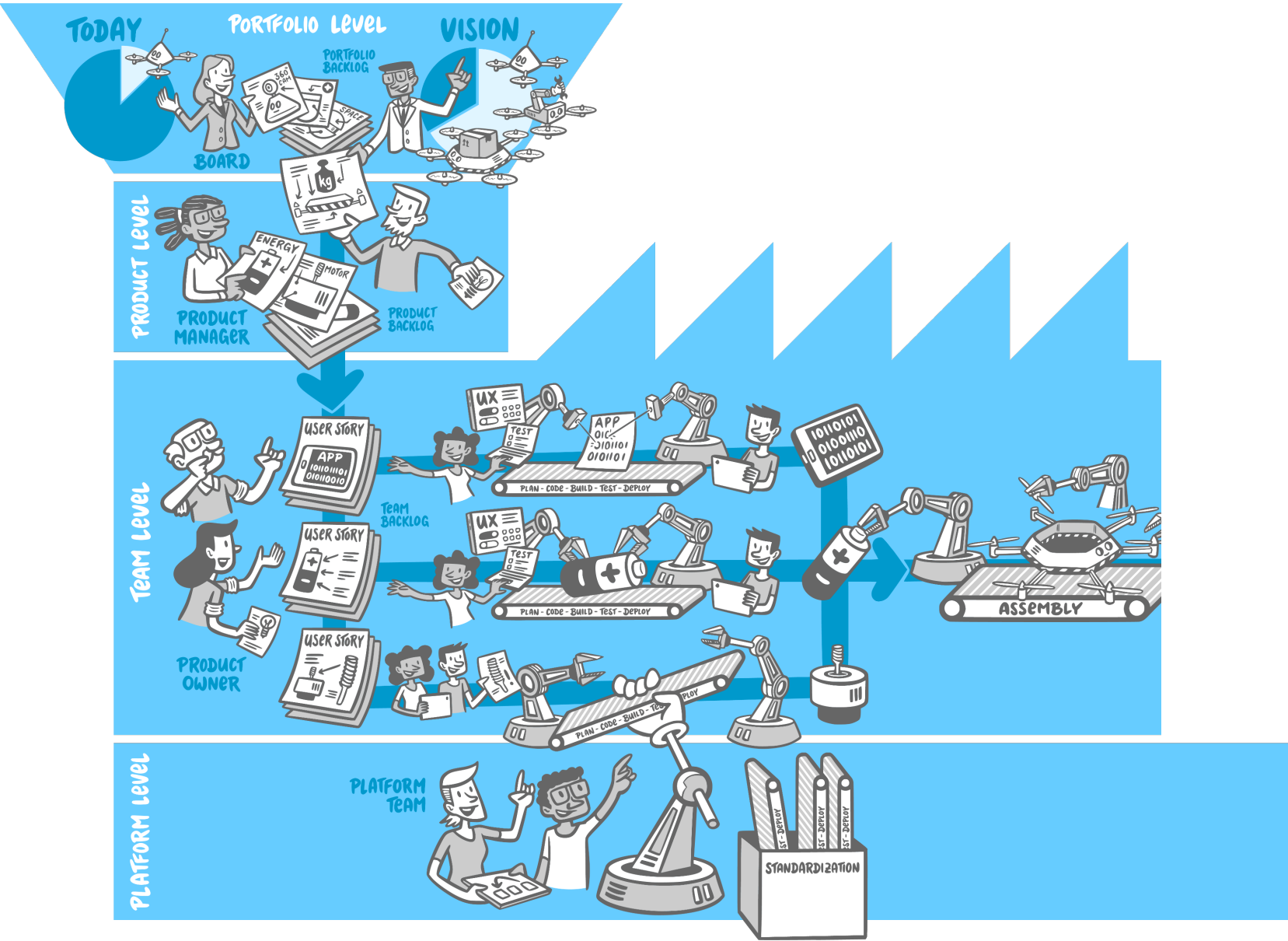
What do we want?

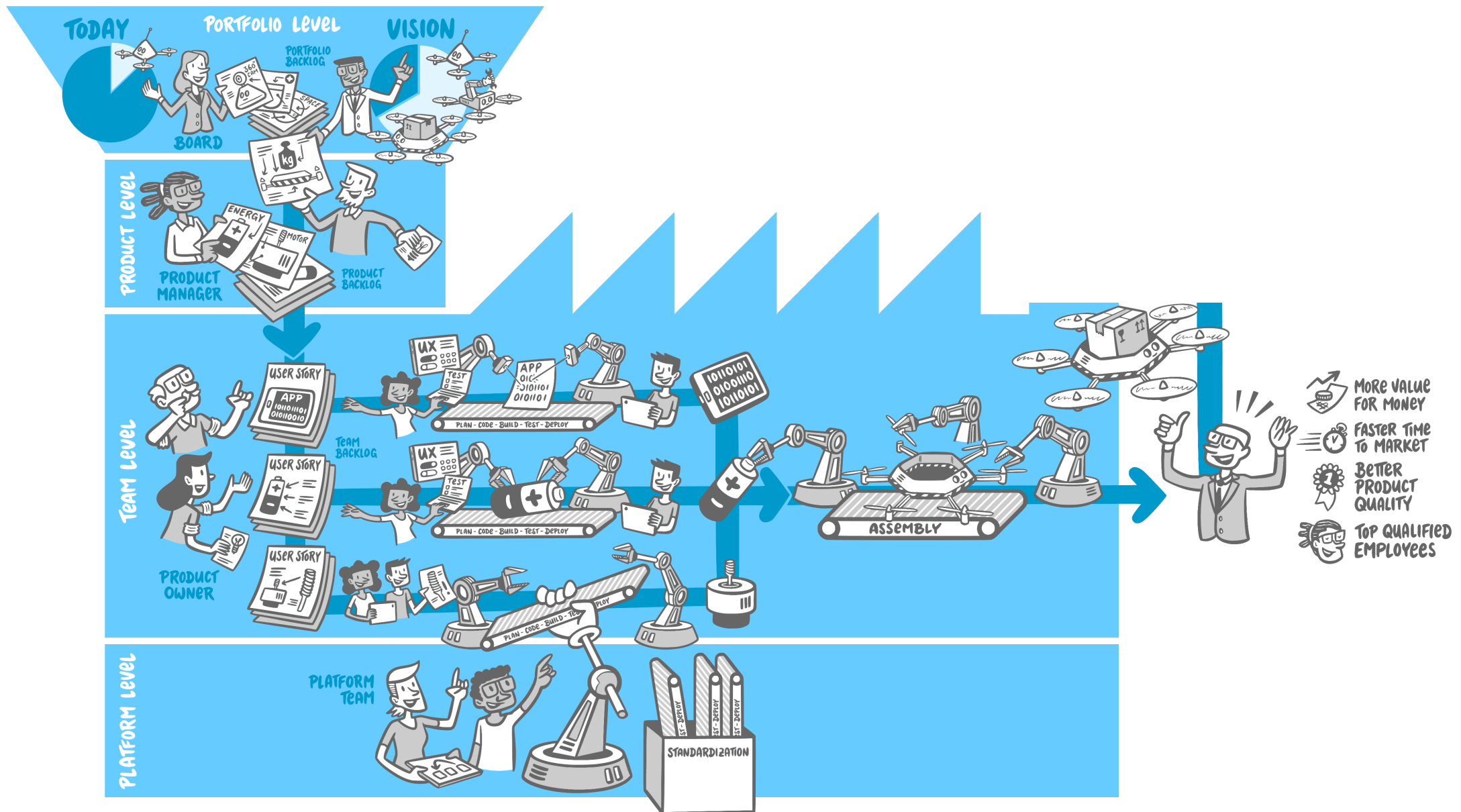


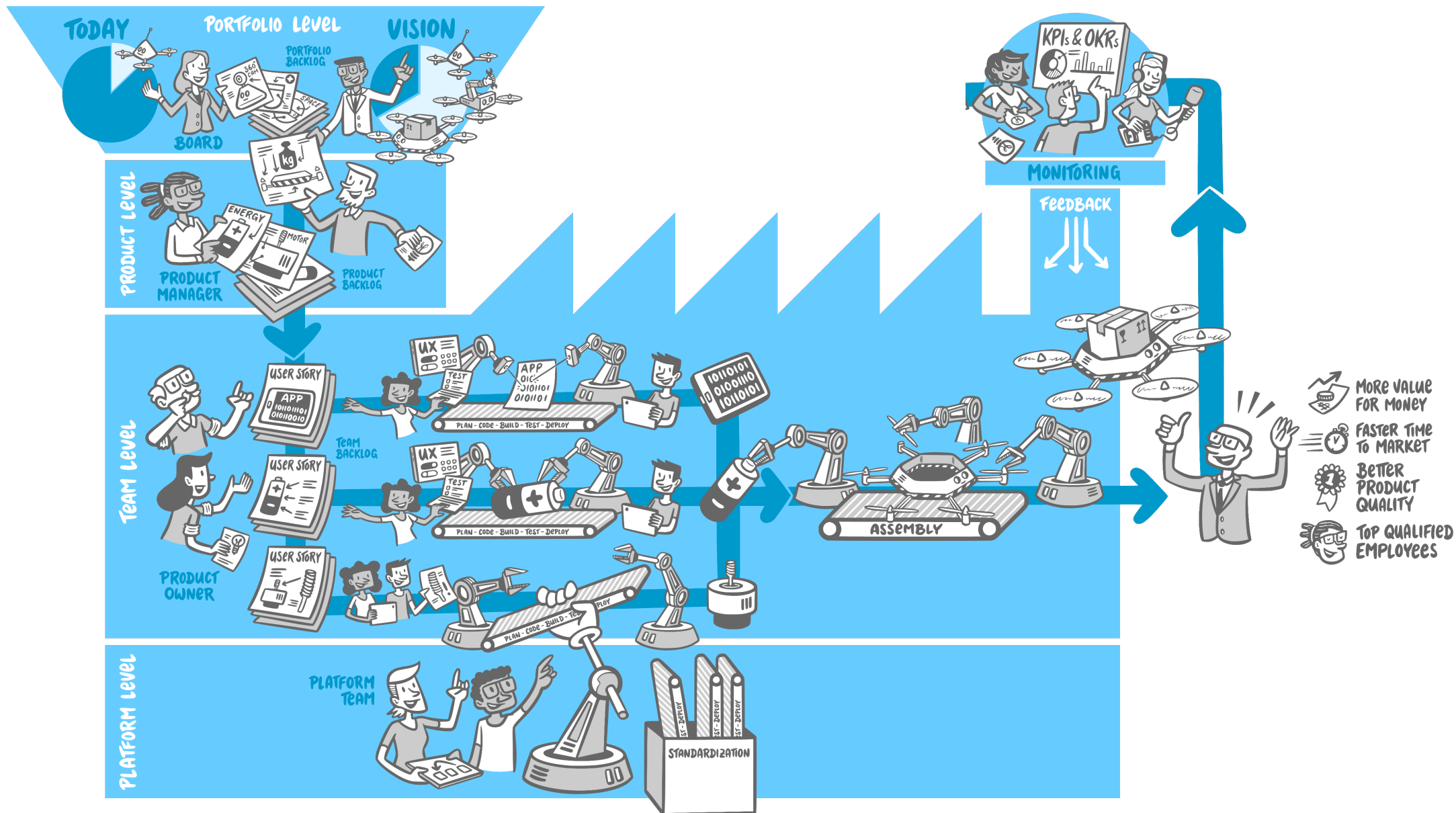


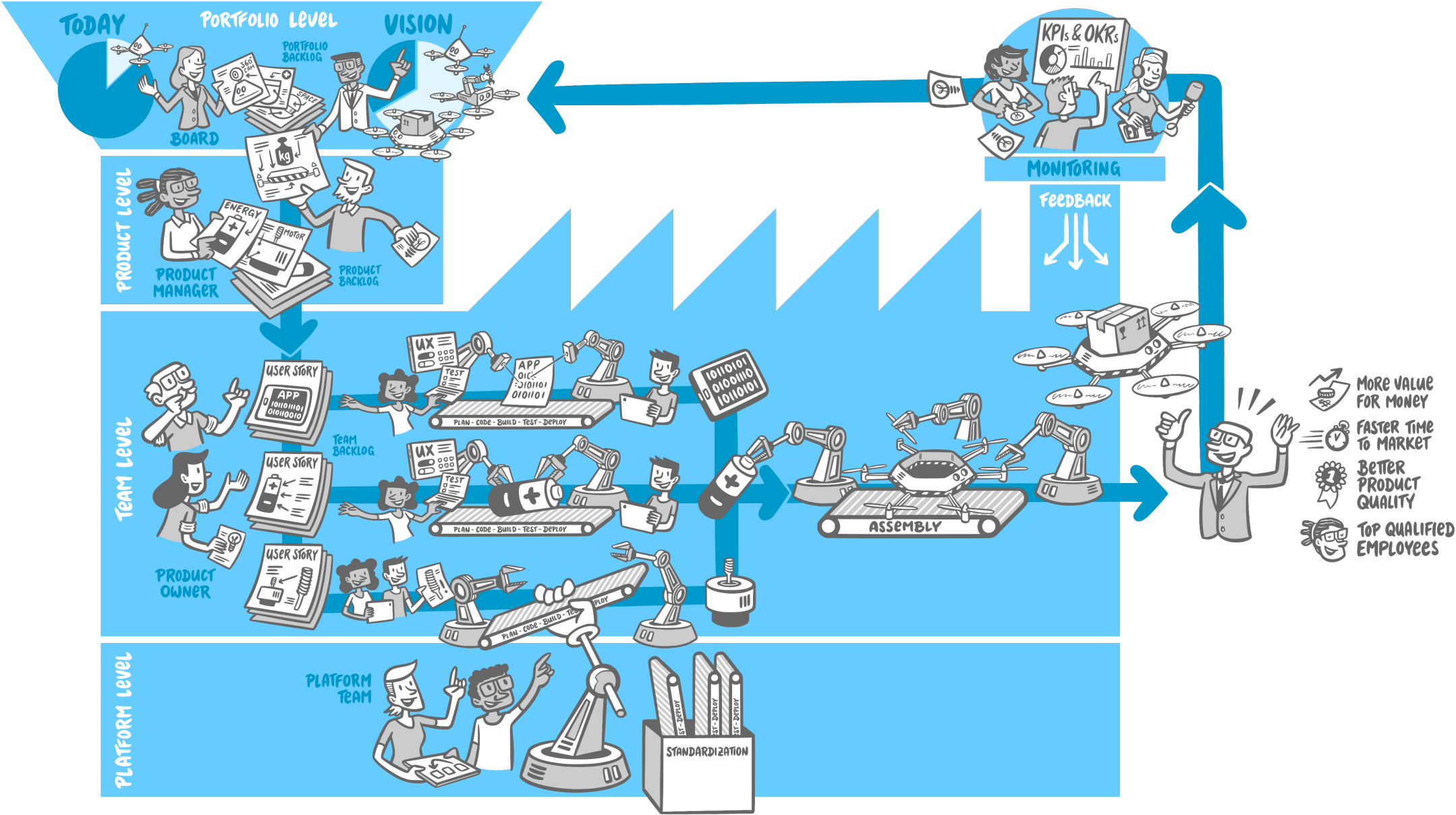




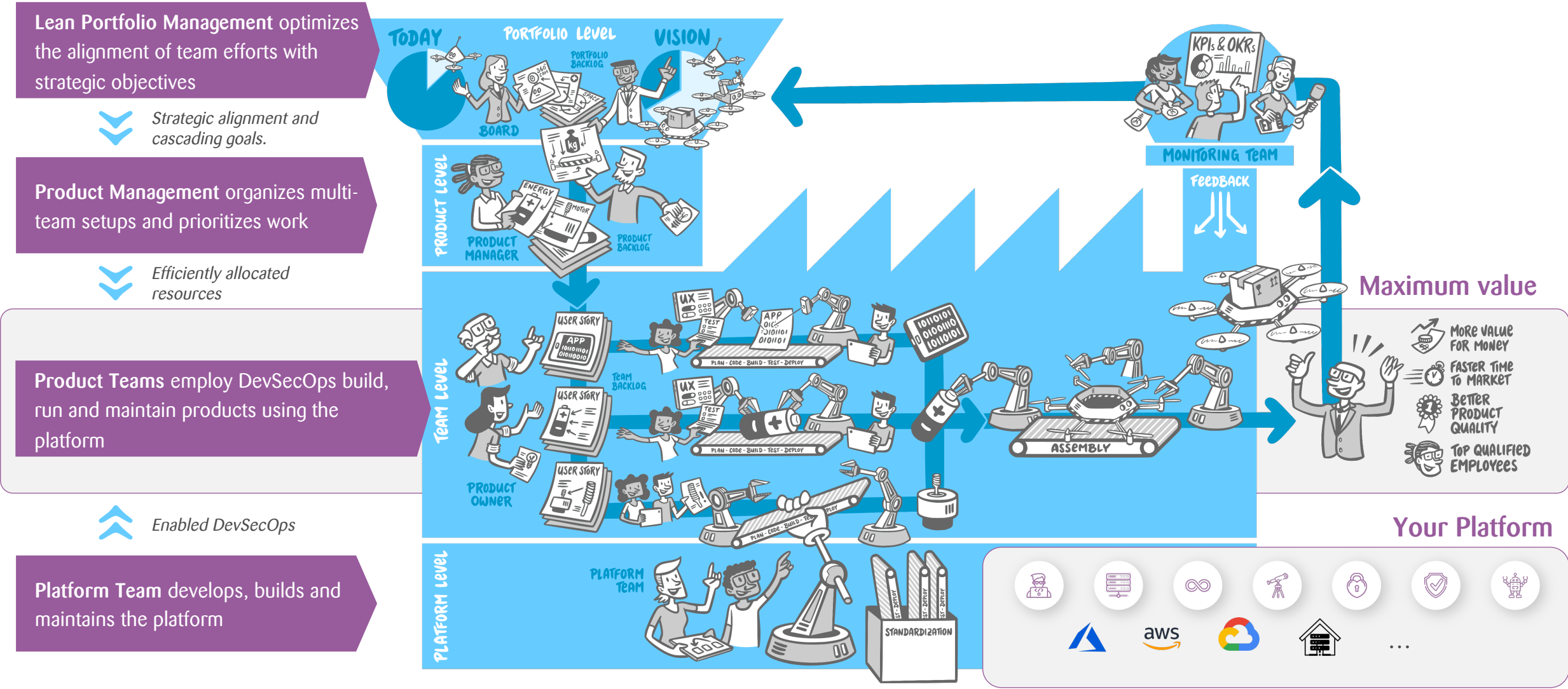








The Digital Factory orchestrates four layers to deliver maximum value



Let's have a closer look at platform engineering.

Platform Engineering: Industrialization of Software Engineering

Distributed and heterogeneous Development Environments

internal and with partners

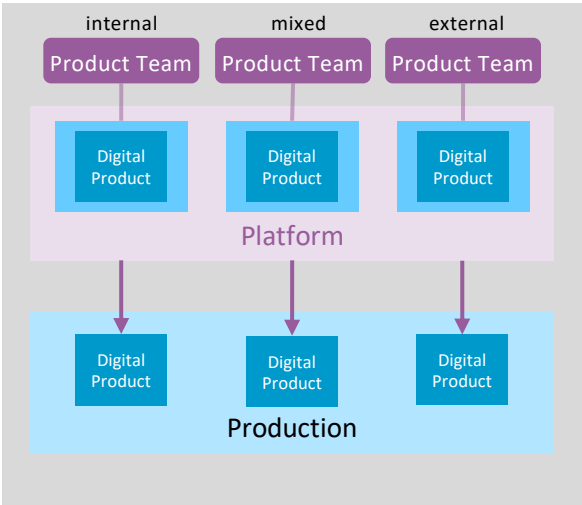
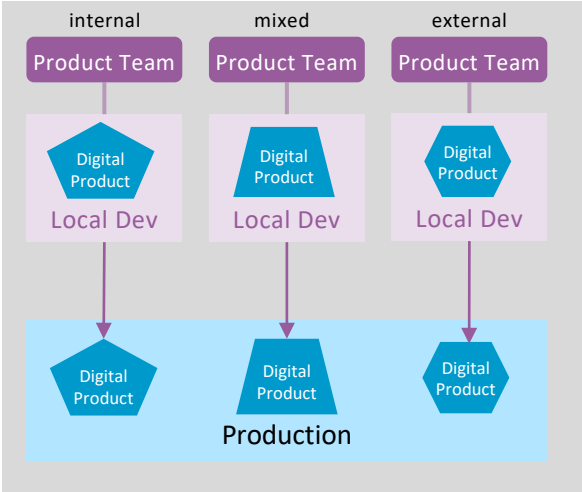
from



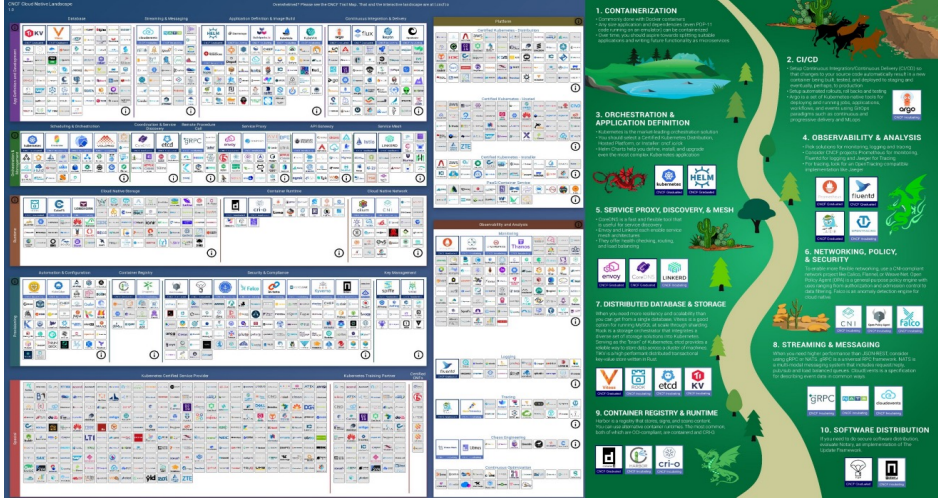
to

Platform

internal and with partners



Source: CNCF



Huge Tool Landscape

from



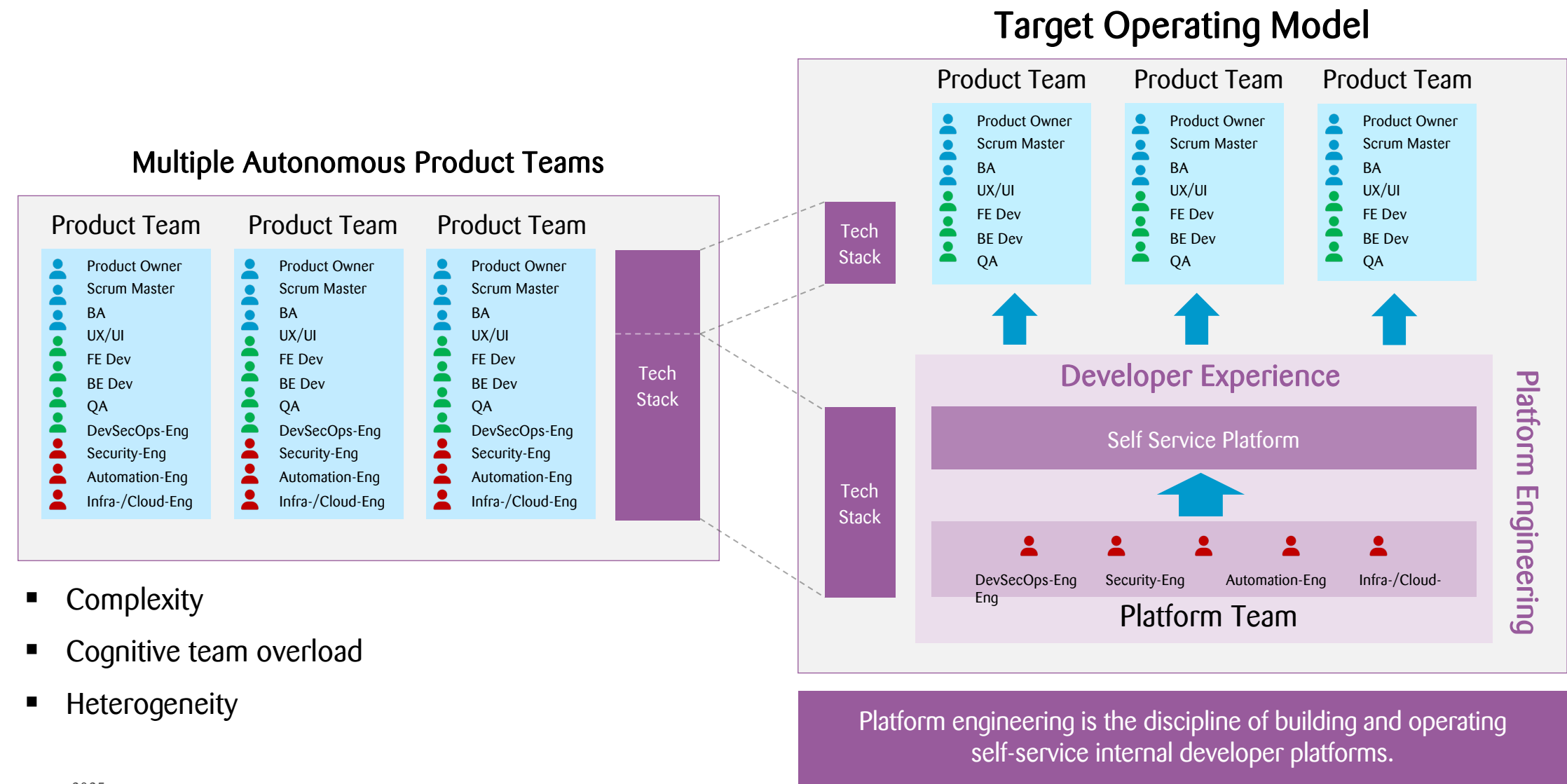
to

Standards of preselected Services and Products (paved paths)

- | Services |
|--|
| ■ Kubernetes (AKS) |
| ■ Crossplane |
| ■ Kafka |
| ■ Ingress NGINX |
| ■ MQ: RabbitMQ |
| ■ API Gateway: Tyk, Gloo |
| ■ DB: MS SQL, MySQL, Oracle, PostgreSQL, MongoDB, MariaDB, Redis, ElasticSearch, Neo4j |
| ■ S3: MinIO |
| ■ IDP: Azure Entra, Keycloak |

- | Products | |
|-------------------|--------------|
| ■ GitLab | ■ Kyverno |
| ■ JFrog | ■ Tempo |
| ■ ArgoCD | ■ Calico |
| ■ Hashicorp Vault | ■ Aqua |
| ■ Prometheus | ■ SonarQube |
| ■ Grafana | ■ Jenkins |
| ■ Open Telemetry | ■ Cypress |
| ■ Trivy | ■ Playwright |

Target Operating Model with Platform Engineering and Platform Team

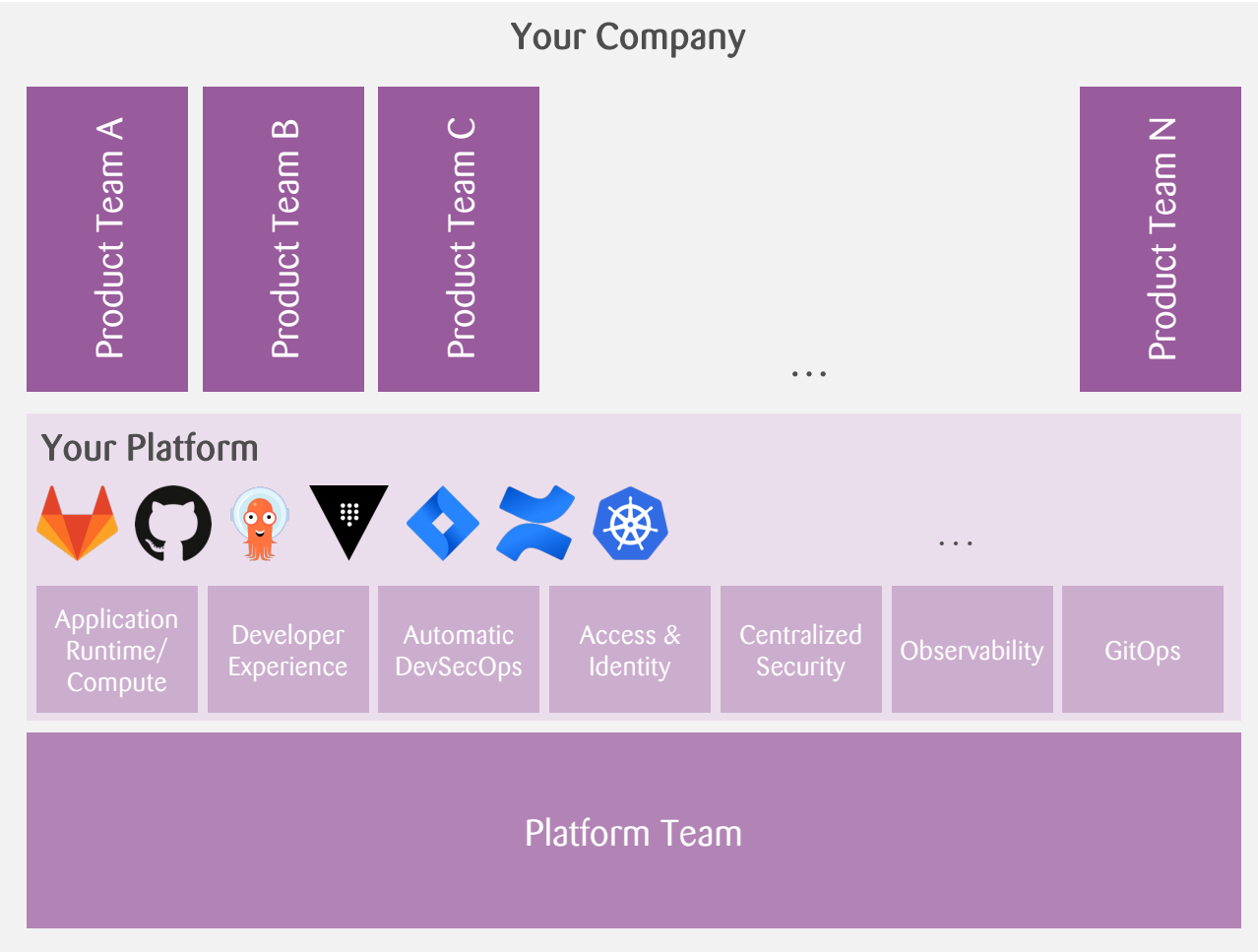


Platform Engineering Enables DevSecOps in Product Teams

Product Teams
Practice DevSecOps to build, run and maintain products, using the platform

↑ **Platform Team**
Delivers the Platform as a Product to Enable **DevSecOps**

Platform Team
develops, builds and maintains the platform



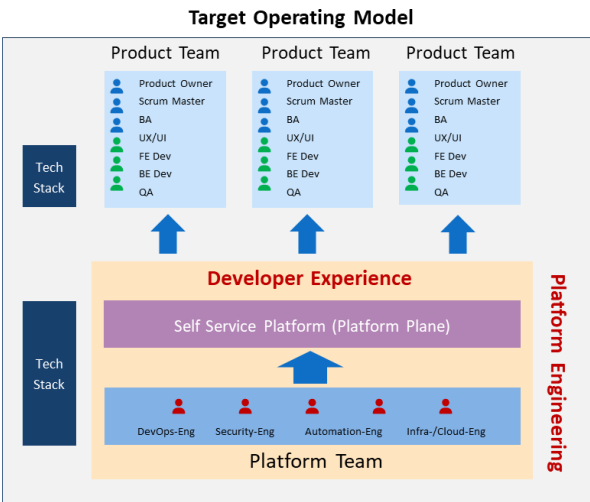
Generates Value for Customers

Generate Value for your Teams

How does that work in a bank?

Delivering High Quality Software Requires the Right Platforms and Tools

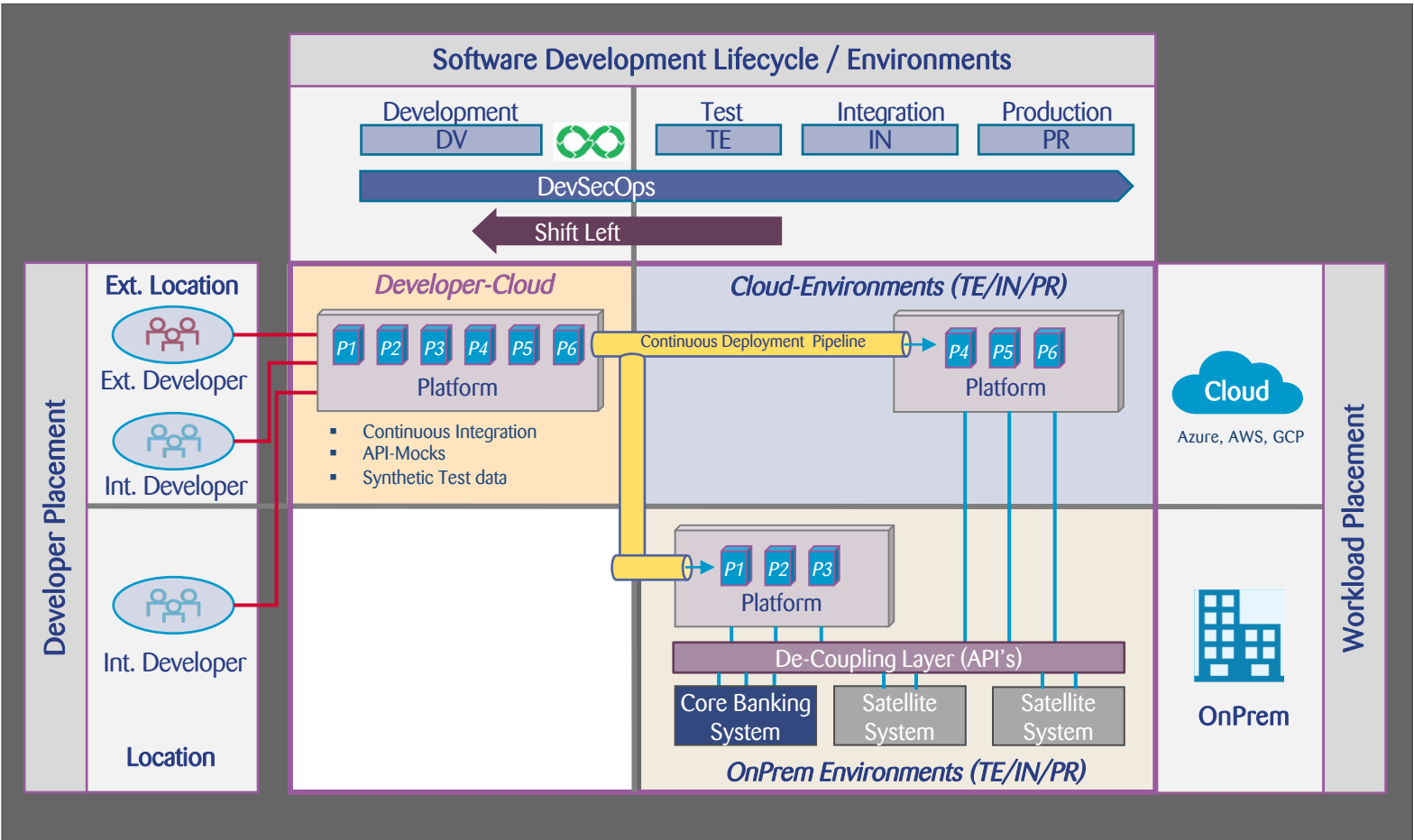
SDLC, Workload placement and Developer placement



Developer Experience

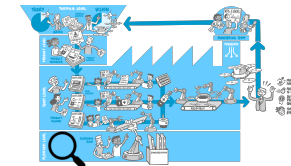
Self Service Platform (Platform Plane)

Services	Products
- Kubernetes (AKS) - Crossplane - Kafka - Ingress NGINX - MQ: RabbitMQ - API Gateway: Tyk, Gloo - DB: MS SQL, MySQL, Oracle, PostgreSQL, MongoDB, MariaDB, Redis, ElasticSearch, Neo4j - S3: MinIO - IDP: Azure Entra, Keycloak	- GitLab - JFrog - ArgoCD - Hashicorp Vault - Prometheus - Grafana - Open Telemetry - Trivy - Kyverno - Tempo - Calico - Aqua - SonarQube - Jenkins - Cypress - Playwright



OK, but how does that look like in practice?

High Level Architecture of a Platform



Your Company PO QA Developer BA / RE UX SM Architect



Creating awesome products



CISO



Compliance & Security

Head of Development



On/off boarding

Program Manager



Tracking Cost

Enterprise Architect



Standardization

Platform

Internal Developer Portal

Repository

Artifacts

Packages

K8s

Catalog

Hypervisor

Cost

Admin

Provisioning & Automation (Cross Blocks / Tools)

Unified API

Automation Blocks

Automation Blocks

Block

TBD

Unified Integration Blocks

Repository

Artifacts

Vault

Directory

OIDC

CD

K8s

TBD

Adapters & Connectors

GitLab

GitHub

HashiCorp

Azure AD

ArgoCD

K8s

TBD

Integrated Tools



Your Tool

Runs on



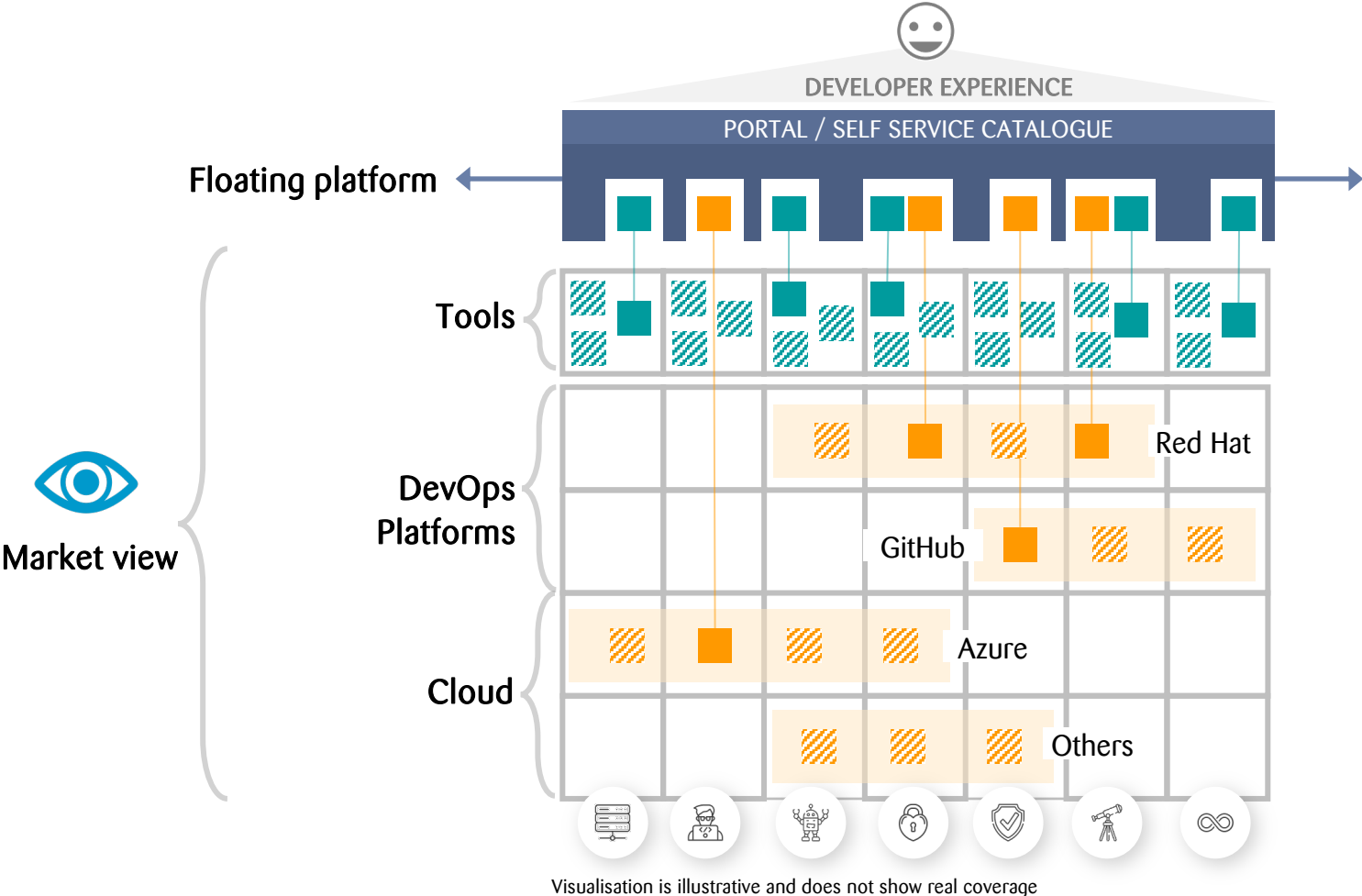
- Application Runtime/Compute
- Developer Experience
- Automatic DevSecOps
- Access & Identity
- GitOps
- Observability
- Centralized Security



- Faster Time to market
- More value for money
- Better quality
- Better Customer satisfaction
- Better Employee satisfaction

Floating platform

A Platform integrates best-in-class tool chains for software product development in a highly efficient way

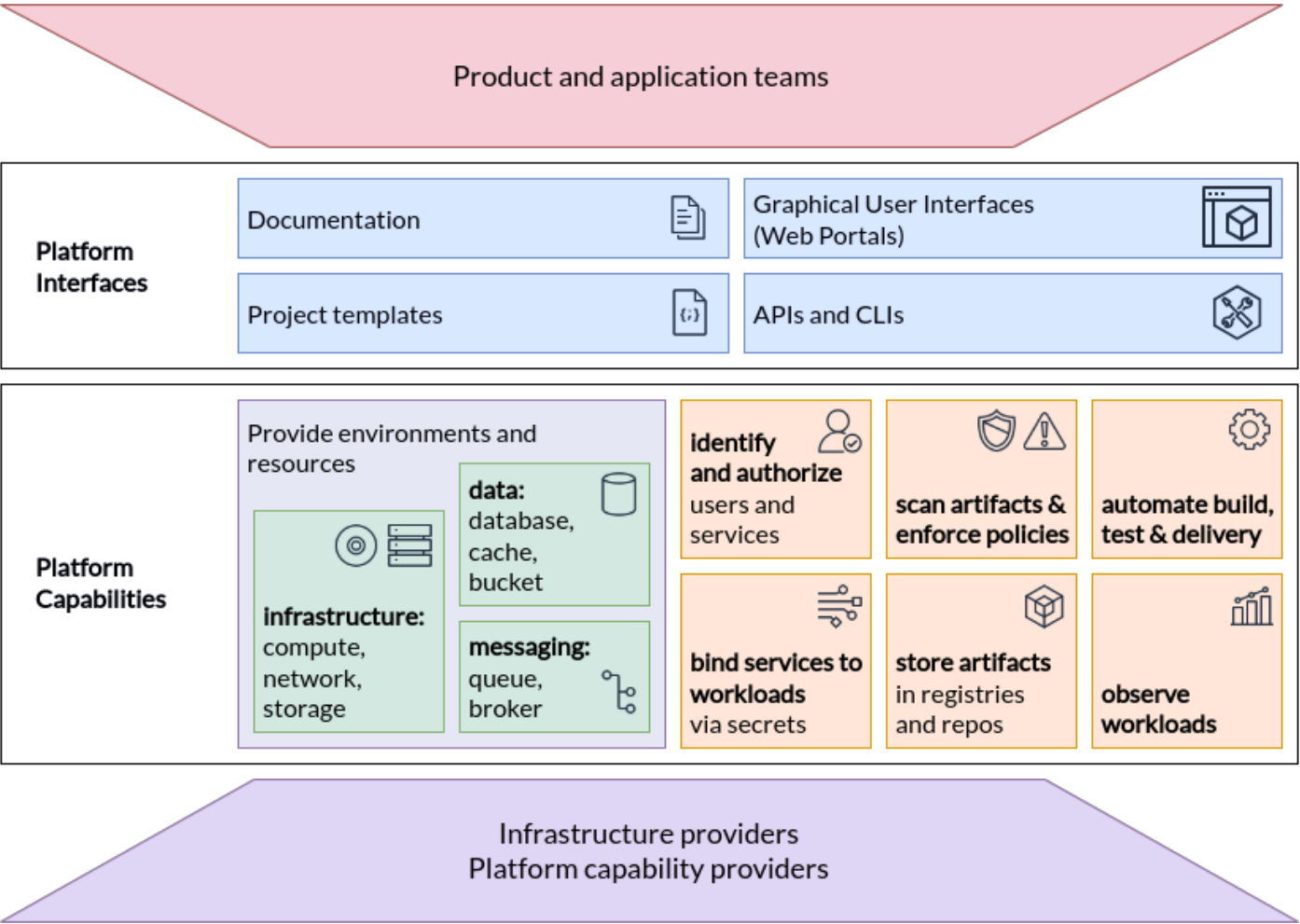


Characteristics of a Platform

- Standing platform team and community able to navigate a rapidly changing tool environment and select the best tools
- Highly efficient, standards-based integration of commercial and open-source tools into the platform
- Covering the entire range of functions across all relevant subject areas
- Excellent developer experience through easy use via portal and self-service catalog
- Supports tool life-cycle management via a managed service catalog
- Utilizes the innovative power and speed of the entire tool and platform provider ecosystem, without lock-in risks

A platform is a critical enabler for a Enterprise

Capabilities of a Platform



- **Governance:** Codify guidelines, rules, and policies, ensuring consistent application across the organization
- **Security:** Provides built-in protection and compliance tools.
- **Integration:** Ensures seamless operation between systems and applications.
- **Scalability:** Supports growth and adapts to changing needs.
- **Standardization:** Reduces complexity and ensures consistency.
- **Efficiency:** Streamlines development and management, saving time and costs.
- **Innovation:** Enables rapid adoption of new technologies.
- **Experience:** Enhances consistency and ease of use.
- **Data Management:** Facilitates data analysis and informed decision-making.

Reference: CNCF Platforms White Paper

BUT ROMANO WHERE IS AI?

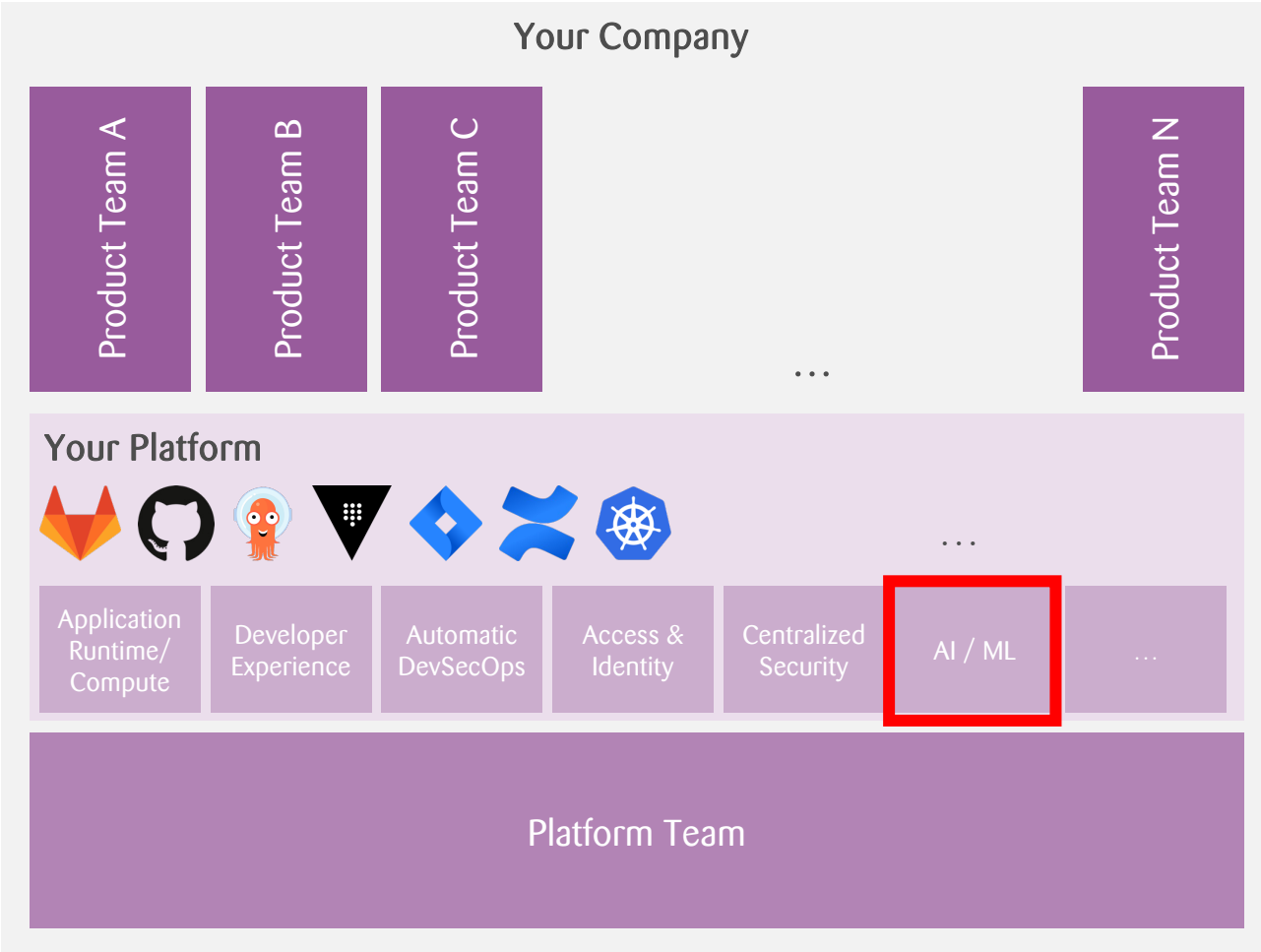
AI IS USUALLY EVERYWHERE

Platform Engineering Enables DevSecOps in Product Teams

Product Teams
Practice DevSecOps to build, run and maintain products, using the platform

↑ **Platform Team**
Delivers the Platform as a Product to Enable **DevSecOps**

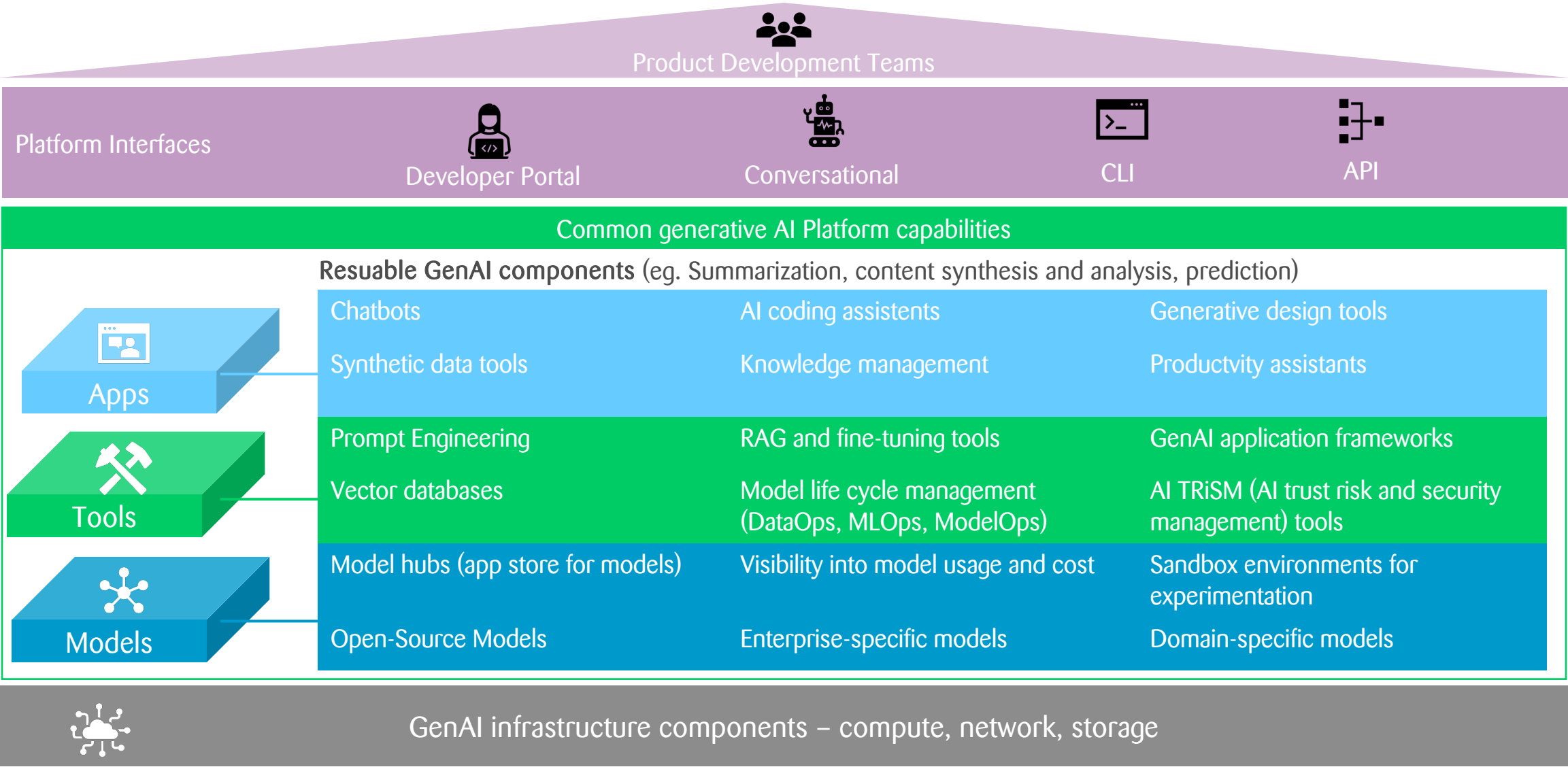
Platform Team
develops, builds and maintains the platform



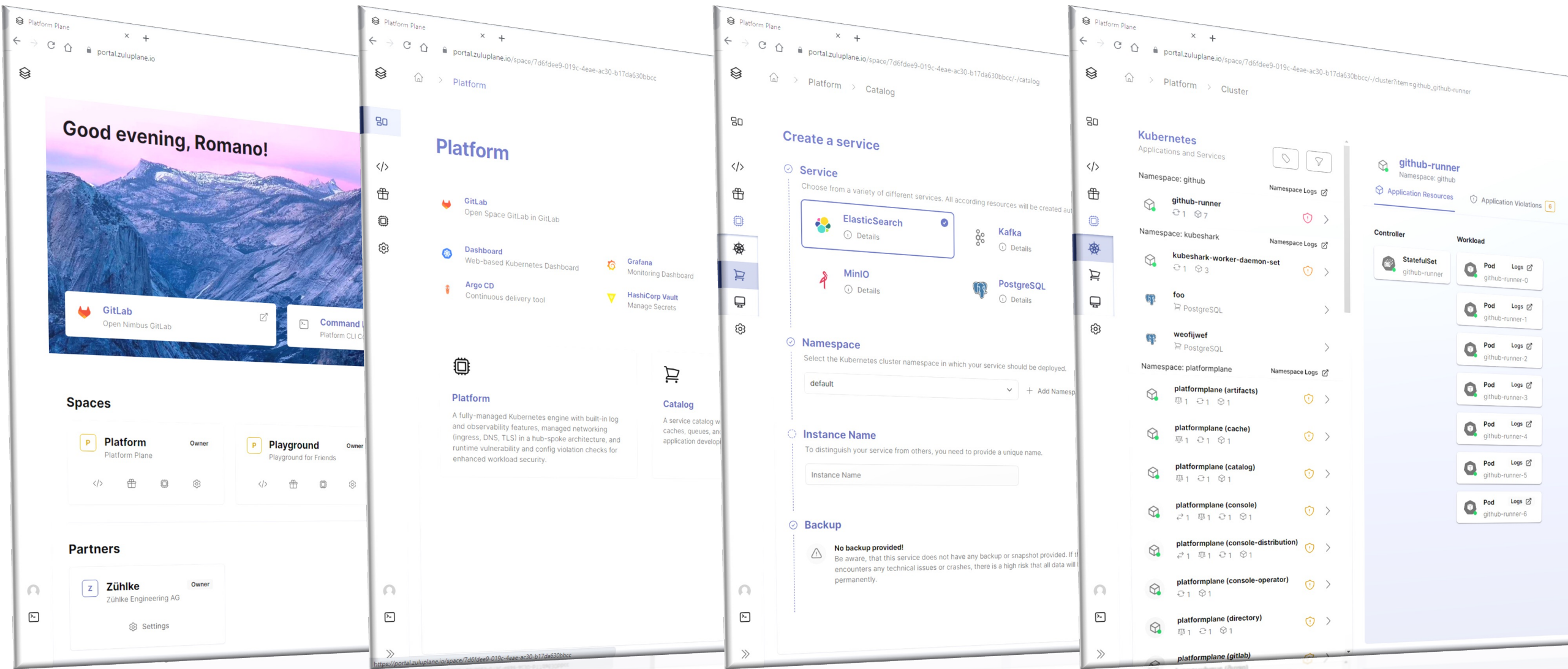
Generates Value for Customers

Generate Value for your Teams

Platform Teams Offer GenAI Capabilities “as a Service” and also use them

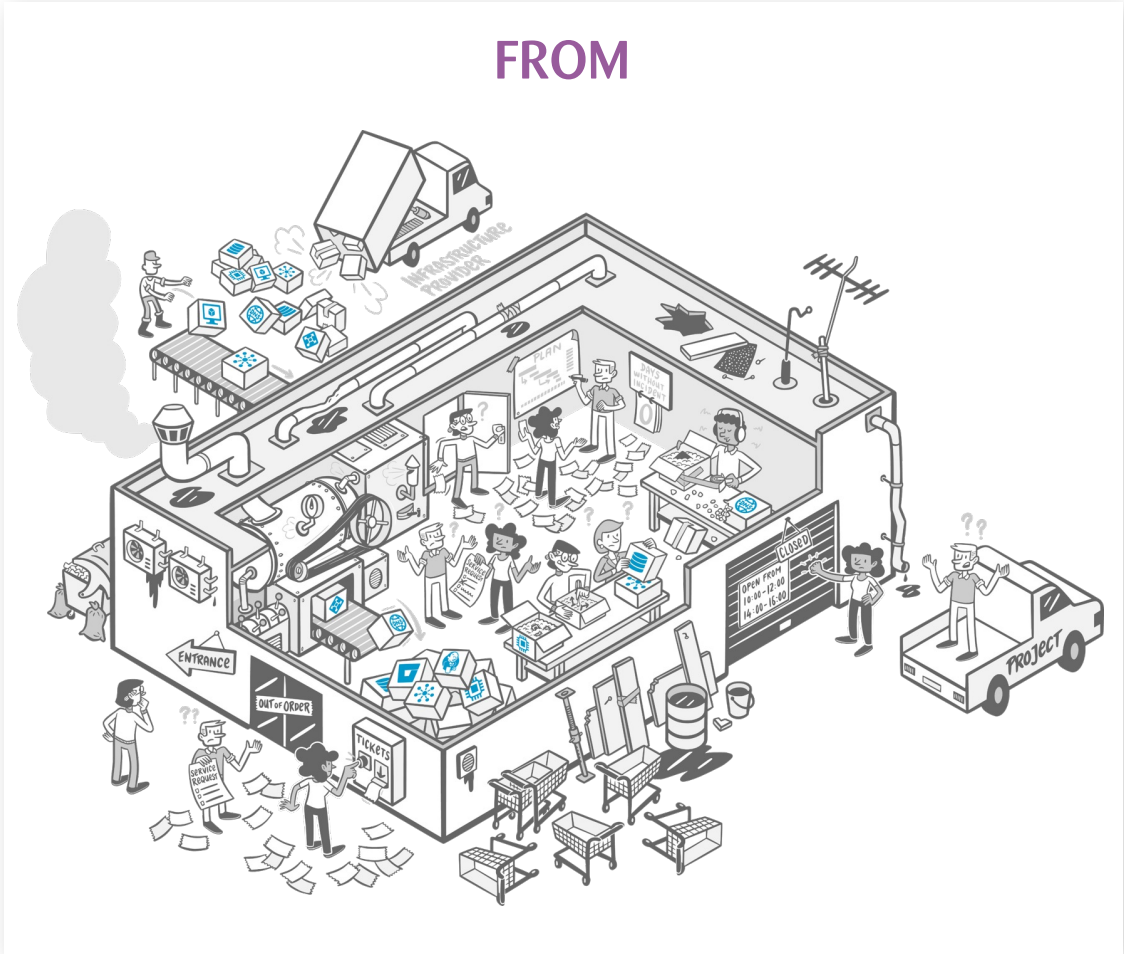


Demo of a platform



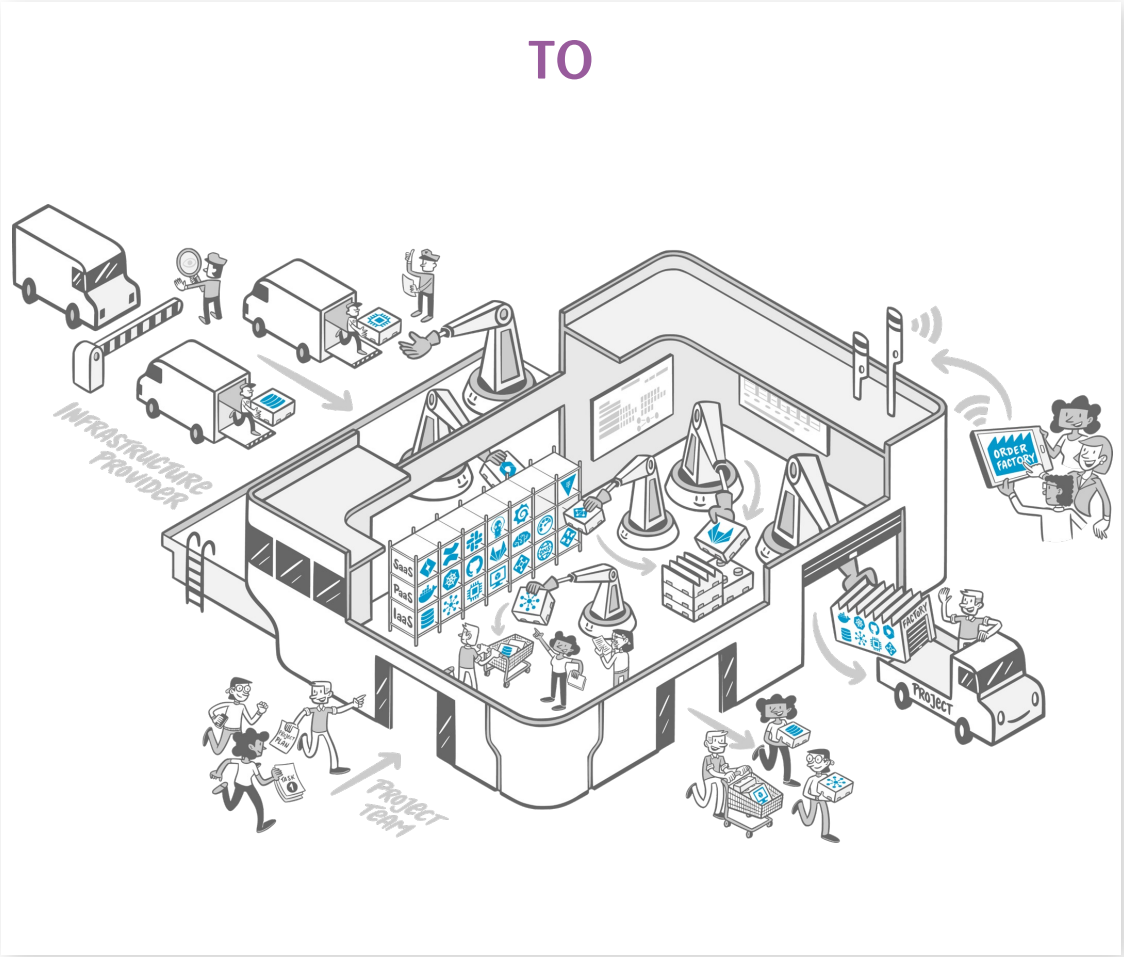
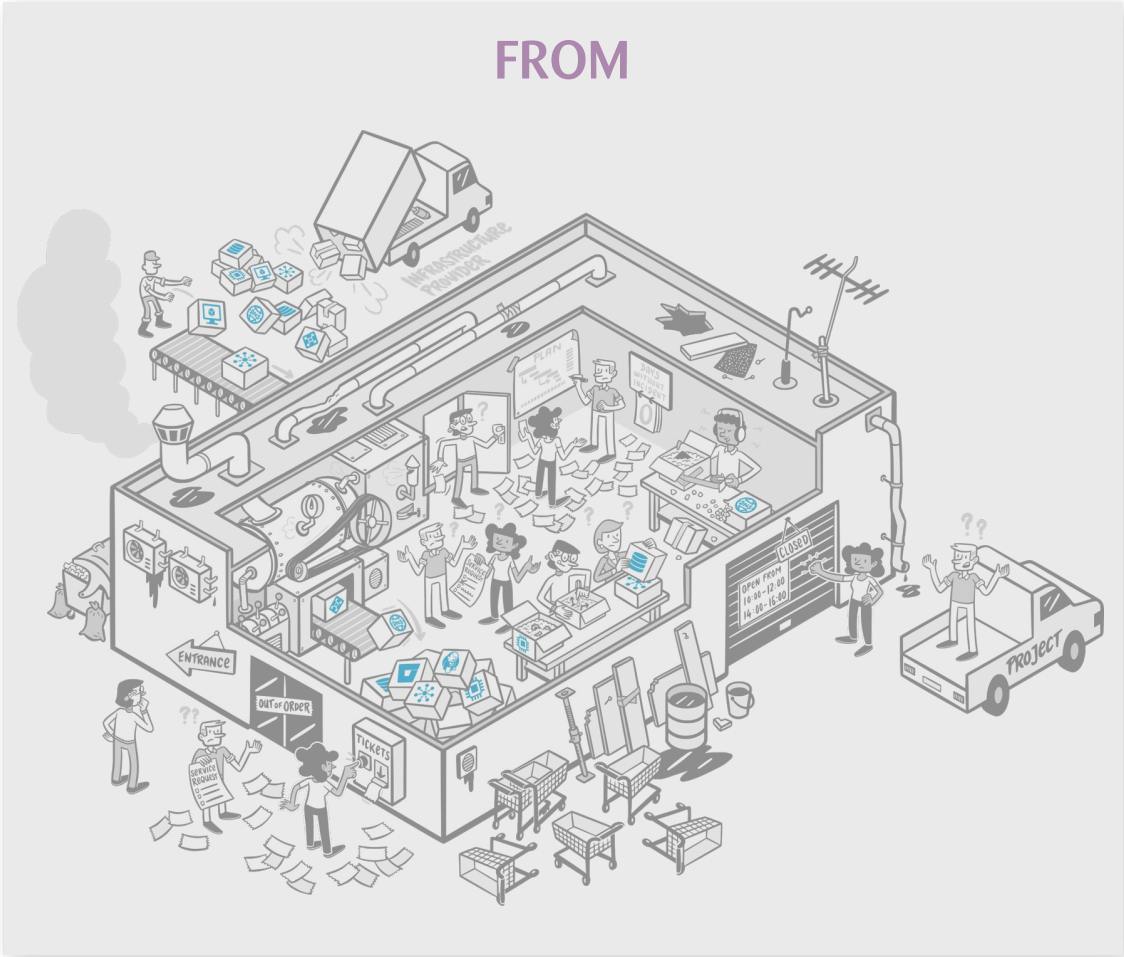
Where is the IT moving?

Enabling IT: Empowering Self-Service IT for Agile, Scalable and Secure Business Transformation



Where is the IT moving?

Enabling IT: Empowering Self-Service IT for Agile, Scalable and Secure Business Transformation



Summary

How Platform Engineering Transforms Modern Application Security

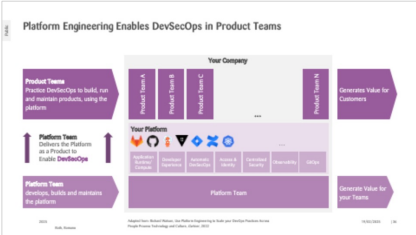
00

DevSecOps is NOT Dead



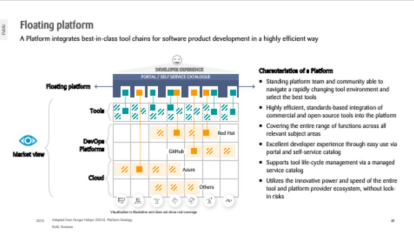
01

Platform Engineering



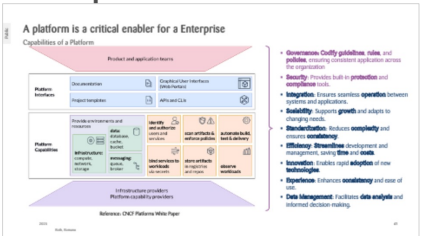
02

Build a floating Platform



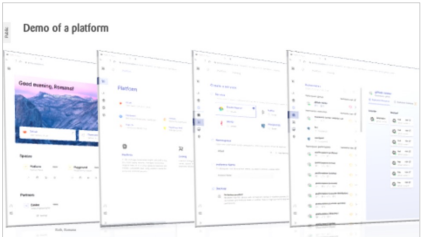
03

Codify security into the platform



04

Build your self-service platform



We are entering the age of industrialization of Software Development

Platform Engineering builds your Platform which is the foundation of your Digital Factory and enables teams to do DevSecOps.

This is the way how to do build in Security!

